Simtora Technologies, Inc.

Information Technology Policy Manual

Document ID	SIM-IT-001
Version	1.1
Owner	Head of IT / Chief Information Security Officer (CISO)
Approved by	Chief Executive Officer
Effective date	September 30, 2026
Review cycle	Annually, or sooner when the law, threat landscape or business changes
Applies to	All employees, contractors, interns, temporary staff and third parties who use or administer Simtora Technologies, Inc. ("Simtora" or "the Company") systems, data or devices
Related manuals	Human Resources Policy Manual (SIM-HR-001); Global People Supplement (SIM-HR-002); International Operations Supplement (SIM-GLB-001, Part 1); Finance and Accounting Manual (SIM-FIN-001); Procurement Policy Manual (SIM-PRC-001); Code of Ethics and Compliance Manual (SIM-CMP-001); Facilities and Office Administration Manual (SIM-FAC-001)

Contents

Introduction

Part 1 – Governance and Organization

- 1.1 IT and Security Governance
- 1.2 IT Strategy, Budget and Cost Management
- 1.3 Policy Framework, Exceptions and Dispensation
- 1.4 Legal, Regulatory and Contractual Compliance
- 1.5 IT Service Management and the Helpdesk
- 1.6 Management Reporting of IT and Security Performance

Part 2 – Information and Asset Management

- 2.1 Data Classification and Handling
- 2.2 IT Asset Management
- 2.3 Software Licensing and SaaS Management
- 2.4 Secure Disposal and Media Sanitization
- 2.5 Data Privacy, Retention and Deletion

Part 3 – Identity and Access Management

- 3.1 Access Control Principles
- 3.2 Authentication, Passwords and Multi-Factor Authentication
- 3.3 Joiner, Mover and Leaver Access Lifecycle
- 3.4 Privileged Access
- 3.5 Access Reviews
- 3.6 Secrets and Cryptographic Key Management

Part 4 – Acceptable Use and End-User Computing

- 4.1 Acceptable Use of Company Systems
- 4.2 Company Devices and Endpoint Standards
- 4.3 Personal Devices (BYOD) and Mobile Device Management
- 4.4 Email, Messaging and Collaboration Tools
- 4.5 Approved AI Tools and AI Governance
- 4.6 Remote Work and Workspace Security

- 4.7 Removable Media, Printing and Physical Documents
- 4.8 Monitoring and Privacy
- 4.9 Website, Domains and Public Digital Presence

Part 5 – Network, Infrastructure and Cloud Security

- 5.1 Network Security
- 5.2 Cloud and Infrastructure Standards
- 5.3 Physical Security of IT Areas and Environmental Controls
- 5.4 Encryption
- 5.5 Logging, Monitoring and Audit Trails
- 5.6 Vulnerability and Patch Management
- 5.7 Malware and Endpoint Protection

Part 6 – Software Development and Change

- 6.1 Secure Software Development Lifecycle
- 6.2 Source Code, Repositories and Build Pipelines
- 6.3 Open-Source Software Policy
- 6.4 Change Management
- 6.5 Environments, Production Access and Customer Data in Non-Production
- 6.6 Outsourced Development and Software Escrow
- 6.7 Software Retirement and Decommissioning

Part 7 – Operations and Resilience

- 7.1 IT Operations and Configuration Management
- 7.2 Backup and Restoration
- 7.3 Business Continuity and Disaster Recovery
- 7.4 Security Incident Management
- 7.5 On-Call and After-Hours Support
- 7.6 Capacity and Availability Management

Part 8 – Third Parties and Customers

- 8.1 Third-Party Risk Management

- 8.2 Contractors and Third-Party Access
- 8.3 Customer Security Requirements and Assurance

Part 9 – Assurance and Enforcement

- 9.1 Security Awareness and Training
- 9.2 Personnel Security
- 9.3 Risk Assessment, Testing and Audit
- 9.4 Vulnerability Disclosure
- 9.5 Enforcement

Appendices

- A. Policy Acknowledgement Form
- B. Joiner, Mover and Leaver Checklists
- C. Security Incident Report Form
- D. Change Request Form
- E. Data Handling Matrix
- F. Exception Request Form
- G. Approval Matrix
- H. Key Standards at a Glance
- I. Glossary
- J. Revision History

Introduction

This Information Technology Policy Manual sets out how Simtora Technologies, Inc. buys, builds, runs, secures and uses technology. As a software company, our systems, source code and customer data are our most valuable assets, and our customers trust us to protect them. This manual applies to every U.S. location and to remote workers, and it complements the Human Resources Policy Manual, which covers the conduct expected of people (see HR 1.9).

Our technology principles

Every policy here follows from seven commitments. Simtora will:

1. **Protect what customers and colleagues entrust to us.** Confidentiality, integrity and availability of data come before convenience.
2. **Give people the access they need, and no more.** Least privilege, unique identities and timely removal.
3. **Build security in.** Security is part of design, code, deployment and operations, not a late check.
4. **Make the secure way the easy way.** Standard tools, single sign-on, managed devices and automation reduce reliance on memory and goodwill.
5. **Assume something will go wrong.** We detect early, report fast, recover quickly and learn without blame.
6. **Be transparent with the people affected.** Employees are told what is monitored; customers are told what they need to know when their data is at risk.
7. **Keep it proportionate.** Controls match the risk, and exceptions are documented, time-limited and approved.

How to use this manual

- **Status of this manual.** This manual is mandatory for everyone in scope. It is a Company policy, not a contract of employment, and does not alter at-will employment (see HR 1.2).
- **Levels of requirement.** "Must" and "must not" are mandatory. "Should" means expected unless there is a documented reason. "May" means permitted.
- **Standards and procedures.** Detailed technical standards (for example, hardening baselines, cloud guardrails and runbooks) are maintained by IT and Engineering under this manual. They may be stricter than this manual, never looser.
- **Changes.** IT may update this manual in line with 1.3. The version on the IT intranet is the current one. Employees are told of material changes by email.
- **Conflicts.** Where this manual conflicts with applicable law, the law governs. Where it conflicts with the HR Policy Manual on a technical matter, this manual governs; on a conduct or disciplinary matter, HR governs. Where a customer contract requires stricter controls, the contract governs for that customer's data and systems.
- **Questions and help.** Contact the IT Helpdesk (**it@simtora.example**). To report a security concern or incident, use **security@simtora.example** or the #security-incident

channel (see 7.4). Ethics concerns go to **ethics@simtora.example**.

- **Acknowledgement.** Every person in scope signs the acknowledgement in Appendix A at onboarding and again when this manual is materially revised.

Locations outside the United States

This manual applies to every Simtora entity and employee: the San Francisco headquarters and the R&D centers in Lahore, Berlin, Paris, Sydney and London. The security standards are the same everywhere. The **International Operations Supplement (SIM-GLB-001), Part 1** sets out what changes because of location: customer-selected hosting regions (U.S., EU, UK, Australia), limits on cross-border access to data, export-control rules for source code, local telecommunications rules (for example, VPN registration in Pakistan), local monitoring-notice rules, and breach-notification clocks. Where this manual refers to U.S. laws or U.S. regions as the default, the Supplement states the position elsewhere.

Roles and responsibilities (summary)

Role	Main responsibilities under this manual
All users (employees, contractors, interns)	Read and follow this manual; protect credentials and devices; complete security training; report incidents and suspected phishing immediately; use only approved tools.
Managers	Ensure their team members complete training and follow policy; request and approve access appropriately; tell IT promptly about role changes and departures; take part in access reviews.
Head of IT / CISO	Own this manual; run IT and security operations; chair the IT & Security Steering Committee; approve exceptions within their authority; report to the CEO and Audit Committee on risk.
IT Operations (Helpdesk, Systems, Endpoint)	Provision and support devices, identities and SaaS; run the asset inventory; maintain patching, backup and monitoring.
Security Team	Run detection and response, vulnerability management, security reviews, awareness training and testing.

Part 1 – Governance and Organization

1.1 IT and Security Governance

Purpose. To make sure technology and security decisions are made by accountable people, with the right business input, and that risk is visible at the top.

Scope. All IT, security and engineering-platform decisions that affect the Company as a whole.

IT & Security Steering Committee (ITSC)

Item	Requirement
Members	CEO (or delegate), CFO, Chief People Officer, General Counsel, Head of IT / CISO (chair), the head of Engineering and the head of Support.
Meetings	Quarterly, plus ad hoc for a critical incident or major decision. Minutes are kept by IT for at least 7 years.
Decides	Annual IT and security roadmap and budget; major technology purchases or migrations; changes to risk appetite; acceptance of high-level risks; annual approval of this manual.
Monitors	Delivery of major IT projects; risk register; audit findings and remediation; incident trends; key metrics (see 1.6).
Project committees	The ITSC may set up a project steering group for any project that is business-critical or exceeds 90 days or the approved budget.

The IT organization

- The **Head of IT / CISO** leads the IT and Security teams. Where the Company later separates the roles, the CISO owns security policy and risk, and the Head of IT owns

operations and delivery. Both must be able to escalate directly to the CEO.

- Roles, responsibilities and authorization levels for every IT position are documented. Duties are arranged so that no single person is a critical dependency; each critical function has a named primary and backup.
- **Segregation of duties.** No one person may both request and approve their own access, changes to production or purchases. Where a small team makes separation impractical, a compensating control (for example, after-the-fact review by a second person) must be approved by the CISO.
- IT staff must have the skills their roles require. The annual plan includes training and certification for IT and security staff.

Responsibilities of the Head of IT / CISO

- Lead and staff IT and Security; run day-to-day IT operations.
- Write, maintain and enforce this manual and its supporting standards.
- Prepare and manage the annual IT and security budget.
- Approve service requests and exceptions within the authority set in Appendix G.
- Maintain the enterprise risk register for technology and information risk.
- Direct the response to security incidents (see 7.4).
- Provide the ITSC, CEO and Audit Committee with accurate, timely risk reporting.
- Ensure continuity of critical IT services (see 7.3).

1.2 IT Strategy, Budget and Cost Management

Purpose. To align technology investment with business strategy and to keep costs visible and controlled.

Scope. All technology spending, including cloud, SaaS, hardware, licenses, contractors and managed services.

Strategy and planning

- IT prepares a **three-year technology roadmap** and a **12-month operating plan** each year, in step with the Company's business plan. The ITSC reviews the roadmap at least

once a year and adjusts it when business strategy changes.

- The plan covers: technology acquisition and retirement, staffing and training, security improvements, resilience, and use of AI and automation.
- IT maintains current documentation of: the application and SaaS landscape, information architecture and data flows, network and cloud architecture, and end-user support processes.

Budgeting and cost control

- IT prepares the annual budget with Finance during the Company's regular budget cycle. Budgets are built on actual operating costs, planned projects and expected growth.
- Costs are tracked monthly and variances above **10%** of the approved line (or **$25,000**, whichever is smaller) are explained to Finance.
- **Cloud cost management (FinOps).** Cloud spend is tagged by team, product and environment. Engineering leaders review spend monthly. Anomaly alerts are set at **20%** above the trailing three-month average, and unused resources are removed. IT and Finance review reserved-capacity commitments before they are signed.
- **Cost allocation.** Shared IT and SaaS costs are charged to the departments that use them, in line with the Finance and Accounting Manual (SIM-FIN-001, 8.4).
- **Purchasing.** All technology purchases follow the Procurement Policy Manual (SIM-PRC-001) and require IT approval first (see 2.3). IT approval is required regardless of purchase amount, because even a free tool can create security and privacy risk.

1.3 Policy Framework, Exceptions and Dispensation

Purpose. To keep the policy set controlled and current, and to handle unavoidable deviations safely.

Document hierarchy

Level	Document	Approved by
Policy	This manual	CEO
Standard	Mandatory technical requirements (for example, "Endpoint Hardening Standard", "Cloud Guardrail Standard")	Head of IT / CISO
Procedure / runbook	Step-by-step operating instructions	Function owner
Guideline	Recommended practice	Function owner

Document control

- A single master copy of each document is held in the IT knowledge base with version history. Only the owner and delegates can edit it.
- Changes are proposed by any department head to the Head of IT / CISO. The Head of IT / CISO reviews them with the people affected and, for changes to this manual, obtains ITSC and CEO approval. Approved changes are published within **5 business days** and notified to all users.
- The manual is reviewed at least once a year. A review that finds no change is still recorded in the revision history (Appendix J).

Exceptions (dispensation)

IT policies are mandatory. A deviation requires a documented, approved exception.

1. The requester completes the Exception Request Form (Appendix F): what is needed, why, the risk, compensating controls, and the proposed end date.
2. The Security Team assesses the risk within **5 business days**.
3. Approval authority follows the risk rating:

Residual risk	Approved by
Low	Head of IT / CISO
Medium	Head of IT / CISO and the data or system owner's department head
High	Head of IT / CISO and the CEO (reported to the ITSC)
Critical	Not permitted without ITSC and CEO approval, and disclosed to the Audit Committee

4. Every exception has an **end date of no more than 12 months** (shorter for high risk). At expiry the requester must comply or request renewal. IT keeps an exception register and reviews it quarterly.

1.4 Legal, Regulatory and Contractual Compliance

Purpose. To ensure Simtora's systems meet the laws and contracts that apply to a U.S. technology company handling customer data.

Scope. All systems and data.

Obligations that shape this manual

Area	Examples	Where it is handled
Computer misuse and access	Computer Fraud and Abuse Act (CFAA), Electronic Communications Privacy Act, state computer-crime laws	3.1, 4.1, 4.8
Privacy	CCPA/CPRA and other state comprehensive privacy laws; COPPA if children's data is involved; state laws on biometrics (for example, Illinois BIPA); GDPR/UK GDPR for any EU or UK customer or employee data	2.5, 8.3
Breach notification	All 50 states' breach notification laws; SEC and sector rules where they apply; customer contract timelines	7.4
Sector data	HIPAA (if we handle protected health information for customers); PCI DSS (if we process payment card data directly); GLBA and other regulations that flow to us by contract	8.3
Financial reporting	Sarbanes-Oxley IT general controls, where Simtora or a customer requires them	3.5, 6.4
Export controls	Export Administration Regulations (encryption and technical data), OFAC sanctions	8.1, 6.3
Intellectual property	Copyright, software licenses, open-source license terms	2.3, 6.3
Employment law	State monitoring-notice laws (New York, Connecticut, Delaware and others); lawful protected activity	4.8, HR 1.9
Customer and industry frameworks	SOC 2 Type II, ISO/IEC 27001 (target), NIST CSF and NIST SP 800-53/800-171 as reference	9.3

Responsibilities

- **General Counsel** identifies applicable legal requirements, advises IT, and maintains a register of them, reviewed at least annually and whenever the business enters a new sector or state.
- **Head of IT / CISO** maps each requirement to a control, tests the control, and reports gaps.
- **Department heads** must report any actual or suspected breach of a compliance requirement to IT Security and Legal as soon as they learn of it, and in any case within **24 hours**.
- Legal holds issued by the General Counsel override normal deletion schedules (see 2.5).

1.5 IT Service Management and the Helpdesk

Purpose. To provide reliable, measurable support to employees and to manage the services IT delivers.

Helpdesk

- The **IT Helpdesk** (**it@simtora.example**, the #it-help channel and the ticket portal) is the single point of contact for support requests, incidents and access requests.
- The Helpdesk records every request, resolves it or escalates it to a specialist or vendor, keeps the requester informed, and reports service metrics.
- Support hours are Monday–Friday, 7:00–19:00 Eastern time, with an on-call engineer for urgent issues outside those hours (see 7.5). Remote workers have the same support as office workers.

Service targets (internal service levels)

Priority	Definition	First response	Target resolution
P1 – Critical	Company-wide outage, security incident or a blocked business-critical function	15 minutes	4 hours or workaround
P2 – High	A team blocked, or a critical function degraded	1 hour	1 business day
P3 – Normal	A single user affected, workaround available	4 business hours	3 business days
P4 – Low	Requests, questions, improvements	1 business day	10 business days

- Standard access requests and new-device setup follow the timescales in 3.3 and 2.2.
- Each service (for example, email, VPN/zero-trust access, source control, CI/CD, production platform) has a documented owner, target availability and support model. Service Level Agreements with vendors and internal service levels are reviewed **at least annually** and are subject to change control.
- Users are surveyed after ticket closure and quarterly for satisfaction. Results go to the ITSC.

1.6 Management Reporting of IT and Security Performance

Purpose. To give leaders the information they need to govern technology and cyber risk.

Report	Audience	Frequency	Typical contents
Operational dashboard	Head of IT / CISO, Engineering leaders	Weekly	Ticket volumes and SLAs, patch status, open vulnerabilities, backup success, uptime
ITSC report	ITSC	Quarterly	Roadmap progress, budget vs. actual, risk register changes, incidents, audit findings, exception register, training completion, vendor risk
Executive summary	CEO and Executive Team	Monthly	Top risks, major incidents, key metrics, decisions needed
Audit Committee briefing	Audit Committee	At least twice a year	Cyber risk posture, significant incidents, results of independent tests and audits, status of SOC 2 and similar
Vendor performance	ITSC	Quarterly	Service levels delivered by critical vendors and outsourced providers

Key metrics the Company tracks include: mean time to detect and to contain incidents; percentage of managed devices compliant (encrypted, patched, EDR active); critical and high vulnerabilities open beyond target; phishing-simulation reporting rate; security-training completion; access-review completion; backup restore-test success; and availability against target.

Part 2 – Information and Asset Management

2.1 Data Classification and Handling

Purpose. To ensure information gets protection in proportion to its sensitivity and importance.

Scope. All information created, received, stored or transmitted by or for Simtora, in any form.

Classification levels

Level	Definition	Examples
Public	Approved for release to anyone.	Published website content, press releases, published documentation, marketing collateral
Internal	For use within Simtora and trusted partners. Disclosure would cause limited harm.	Internal wiki, org charts, general policies, non-sensitive meeting notes
Confidential	Disclosure could cause significant harm to Simtora, its customers or individuals.	Source code, product roadmaps, customer lists and contracts, pricing, financial results before release, security architecture, employee HR records, non-public vendor terms
Restricted	Highest sensitivity; disclosure could cause severe harm, legal liability or mandatory notification.	Customer production data and personal data, authentication secrets and encryption keys, government IDs and Social Security numbers, bank and payment data, health data, legal-privileged material, unreleased M&A or material non-public financial information, security vulnerability details before remediation

- **Default.** Information that has not been labeled is treated as **Internal**. Anything containing personal data of customers or employees, credentials or keys is **Restricted** regardless of label.
- **Owner.** Every data set and system has a **data owner** (a department head or delegate) who assigns the classification, approves access and reviews it. If in doubt, classify higher and ask IT Security.
- **Labeling.** Documents, repositories, cloud storage locations and databases are labeled or tagged where the tooling allows (for example, sensitivity labels in the document platform, tags on cloud resources). Physical hardware is labeled with an asset tag (see 2.2).
- **Handling.** Appendix E sets out how each class may be stored, shared, transmitted, printed and destroyed. Summary rules:
  - Public and Internal data may be used in approved Company tools.
  - Confidential data may be shared outside the Company only under a signed NDA or contract and only via approved channels.
  - Restricted data may be stored only in approved, encrypted, access-controlled systems; never on laptops beyond what is technically necessary, never in email attachments, chat, personal storage or unapproved AI tools; and only for people with a documented need.
- **Reclassification.** Data owners reclassify information when its sensitivity changes (for example, financial results become Public on release).

2.2 IT Asset Management

Purpose. To know what we own, who has it, and how it is protected throughout its life.

Scope. Hardware (laptops, mobile devices, servers, network equipment, peripherals), software and SaaS, cloud resources, and information assets.

Asset lifecycle

Stage	Requirement
Acquire	Buy through IT (or IT-approved channels) under the Procurement Policy Manual (SIM-PRC-001, 6.2). New hardware is delivered to IT for imaging and enrollment.
Register	IT records each asset within **1 business day** of receipt: serial number, asset tag, model, owner, location, purchase date, warranty, classification and criticality.
Issue	Devices are enrolled in device management, encrypted, and assigned to a named person before use. The user signs a receipt.
Maintain	Patches, warranty and repairs are tracked (see 5.6). Unauthorized hardware or software changes are not allowed.
Move or reassign	Any transfer between people, locations or teams is approved by IT and recorded within **2 business days**.
Retire	Assets are wiped, decommissioned and disposed of under 2.4.

Inventory and labeling

- IT holds a **single authoritative inventory** of hardware, software, SaaS applications, cloud accounts and data stores. It is reconciled against device-management and cloud tools **at least monthly**, and physically verified for network and server equipment **at least annually**.
- All physical IT assets carry an asset tag with a unique ID. Sensitive equipment also carries its classification.
- Original software installation media, license keys and agreements are stored securely in the license repository.

Criticality

Each system and service is rated by its owner with IT:

Rating	Meaning	Examples
Tier 0 – Critical	Loss stops the business or customer service; no easy substitute	

The criticality tier drives backup, recovery, monitoring and change requirements (see 7.2, 7.3, 6.4).

Refresh and equipment standards

- **Laptops** are replaced after **4 years** or earlier if performance, security support or repair cost requires. Standard configurations are set by IT for each role (for example, general business, engineering, data/AI); exceptions need manager and IT approval.
- **Mobile phones** are provided for roles that need them (see HR 7.4) and follow the same enrollment and encryption rules.
- Home-office equipment purchased under the HR stipend ($500 one-time, up to$ 1,000 for fully remote employees; see HR 7.4) must meet IT's peripheral standards. Peripherals such as monitors, keyboards and headsets are Company-owned and inventoried when purchased with Company funds; IT is not required to support personal-brand equipment.
- **Loss, theft or damage.** Report lost or stolen equipment to IT Security within **1 hour** of discovery (see 7.4). IT locks or wipes the device remotely. Employees are not charged for lost or damaged equipment, consistent with the HR manual; repeated, deliberate or grossly negligent loss is dealt with under corrective action (HR 2.3).
- **Insurance.** Finance maintains coverage for IT equipment and cyber liability.

2.3 Software Licensing and SaaS Management

Purpose. To make sure all software is licensed, approved and reviewed for security before use.

- **Licensed only.** Only properly licensed software and services may be used on Company systems or to handle Company data. Users must not install pirated, cracked or unlicensed software.
- **Approved catalog.** IT maintains a catalog of approved software and SaaS tools. Standard tools are self-service through the software portal.
- **New tools.** Before any new software, SaaS product, browser extension, plugin or integration that touches Company or customer data is used (including free or trial versions and tools that connect to Company email, calendar, drive or repositories), the requester submits a **security and privacy review** request. The review covers: data types

and classification, authentication (SSO/MFA support), encryption, vendor security posture (for example, SOC 2 report), data location and subprocessors, terms of service, and cost. Target turnaround is **5 business days** for standard reviews and **10 business days** for tools handling Restricted data.

- **Shadow IT.** Unapproved tools discovered by IT are reviewed; where they pose unacceptable risk, use must stop and data must be migrated or deleted. Discovery of unapproved use is an opportunity for coaching, not by itself corrective action, unless it was a deliberate bypass of a known control.
- **License compliance.** IT tracks entitlements versus use, reclaims unused licenses (inactive over **60 days**), and prepares for vendor audits. Legal is told immediately of any vendor audit notice.
- **Owners.** Each SaaS application has a business owner and a technical owner recorded in the inventory. Owners approve access and take part in access reviews (see 3.5).
- **Renewals.** IT and Procurement review contracts **90 days before renewal** to confirm need, cost and security posture.

2.4 Secure Disposal and Media Sanitization

Purpose. To ensure no Company or customer data leaves Simtora on retired equipment or media.

- **Sanitization standard.** Storage media are sanitized following NIST SP 800-88 (Clear, Purge or Destroy) according to data sensitivity and media type. Managed laptops and phones are cryptographically erased and factory-reset; drives that held Restricted data and failed or unreadable media are physically destroyed.
- **Certificates.** Vendors used for recycling or destruction must provide a certificate of destruction for each batch and be reviewed under 8.1. IT keeps certificates for **at least 7 years**.
- **Chain of custody.** Retired equipment is stored securely and logged from removal to destruction. Assets awaiting disposal are never left unattended in common areas.
- **Approval.** Disposal, donation or resale of any IT asset needs IT approval and, for assets above the Company's capitalization threshold, Finance clearance (see Finance and Accounting Manual, SIM-FIN-001, 7.3). Disposal follows applicable e-waste laws and recycling requirements; employees are not to discard electronics in general trash.

- **Cloud and SaaS.** When a cloud service or SaaS product is retired, IT confirms in writing that data has been deleted by the provider, or exports and deletes it as appropriate, subject to retention and legal-hold requirements.
- **Paper and documents.** Printed Confidential or Restricted material is shredded (cross-cut) or placed in locked shred bins.
- **Employees.** Departing employees return all Company devices under HR 9.4. Employees may not keep, sell or repurpose Company hardware without written IT approval.

2.5 Data Privacy, Retention and Deletion

Purpose. To handle personal information lawfully and keep data no longer than needed.

Scope. Personal information of customers, users, employees, candidates and business contacts.

Privacy principles

- **Collect the minimum** personal information needed, for stated purposes.
- **Use it only** for those purposes, or as the law permits.
- **Protect it** with controls suited to its classification (see 2.1).
- **Honor rights.** Legal and IT operate a documented process to respond to access, correction, deletion, opt-out and portability requests from individuals within the statutory timeframe (generally **45 days** under most state laws, extendable as the law allows).
- **Privacy by design.** New products and features that handle personal data undergo a privacy review by Legal and Security before launch.
- **Data mapping.** IT and Legal maintain a record of what personal data is held, where, why, and who it is shared with, reviewed annually.

Retention

Data type	Minimum retention (unless law or contract requires longer)
Security and access logs	12 months (see 5.5)
Change and incident records	3 years
Access-review evidence, ITSC minutes, exception register	7 years
Backups	Per 7.2 (generally 35 days online; up to 12 months for archival tiers)
Customer data	Per customer contract; deleted within **30 days** after termination of the contract or a verified deletion request, and from backups on the normal backup expiry cycle
Employee records	Per the HR Policy Manual and applicable law
Email and messaging	Per the retention schedule set by Legal (default 3 years, then deleted)

- The **General Counsel** owns the records retention schedule. Data past its retention period is securely deleted unless subject to a **legal hold**, which suspends deletion until Legal releases it. IT implements holds within **1 business day** of notice.
- **Data location.** Restricted data is hosted in the region the customer selects (United States, European Union, United Kingdom or Australia); where no region is selected it is hosted in U.S. regions unless a customer contract, or an approved review, permits otherwise. Access from other countries follows SIM-GLB-001, Part 1.
- **Breaches.** Any suspected unauthorized access to personal information is a security incident (see 7.4). Legal decides on notice to individuals, regulators and customers.

Part 3 – Identity and Access Management

3.1 Access Control Principles

Purpose. To ensure only authorized people and systems can reach Company information and only to the extent needed.

Scope. All systems, applications, data stores, cloud consoles, repositories and physical IT areas.

- **Need-to-know and least privilege.** Access is granted only where required for the person's role, at the lowest level that allows the work.
- **Unique identity.** Every user has a unique account tied to one individual. **Shared or generic accounts are not permitted**, except for approved service or break-glass accounts that are owned by a named person or team, stored in the secrets vault and logged (see 3.4, 3.6).
- **Single sign-on.** All business applications that support it must be connected to the Company identity provider (IdP) with SSO and MFA. Applications that cannot support SSO need a documented exception (see 1.3).
- **Role-based access.** Access is assigned by role (roles and groups maintained in the IdP), not person-by-person, wherever possible. IT maintains an access matrix that defines standard access for each role and system.
- **Approval.** Access is granted only after approval by the **manager and the data or system owner**. Access to Restricted data or production systems also requires Security approval. No one may approve their own access.
- **Accountability.** Users are responsible for all activity under their accounts. Never lend, share or reuse credentials, MFA codes or sessions.
- **Default deny.** If no access has been granted, none exists.
- **Unauthorized access** to systems or data, including attempts to exceed granted permissions, is prohibited and may violate the Computer Fraud and Abuse Act and state law (see also HR 1.9).

3.2 Authentication, Passwords and Multi-Factor Authentication

Purpose. To make credentials hard to steal and hard to misuse.

Multi-factor authentication (MFA)

Where	Requirement
Company IdP / SSO, email, collaboration, source control, cloud consoles, production and admin tools, HR and finance systems	**MFA required for everyone**, all the time
Remote access (VPN or zero-trust access)	MFA required, plus a compliant managed device
Privileged and administrator access	**Phishing-resistant MFA** (FIDO2 security keys or platform passkeys)
Customer-facing consoles and production data access	Phishing-resistant MFA
SMS or voice codes	Not permitted as an MFA method for Company accounts, except as a documented temporary fallback approved by IT

- MFA prompts must never be approved unless the user has just initiated the sign-in. Unexpected prompts must be reported to IT Security immediately (MFA fatigue attack).
- Users register at least **two** MFA methods (for example, a passkey and a hardware key) to avoid lockout. IT verifies identity through a documented process (video or in-person verification for privileged users, and manager confirmation) before resetting MFA.

Sessions

- Sessions lock automatically after **10 minutes** of inactivity on laptops and **2 minutes** on mobile devices (see 4.2).
- Web session lifetimes for the IdP and sensitive apps are set by IT: **12 hours** for standard apps, **1 hour idle / 8 hours maximum** for admin consoles and Restricted data tools. Sign-in from new devices or unusual locations triggers step-up authentication.

Passwords

Simtora follows current NIST SP 800-63B guidance, which favors length and screening over arbitrary complexity and frequent change.

Control	Requirement
Minimum length	**14 characters** for user passwords; **20 characters** for privileged accounts and shared vault master passwords
Composition	Passphrases encouraged; no forced complexity rules; blocklist of common, breached and Company-related passwords is enforced
Rotation	**No routine periodic rotation.** Change immediately if compromise is suspected or confirmed, or if the password appears in a breach corpus
Reuse	Never reuse a Company password anywhere else
Password manager	Users must use the **Company-approved password manager** for all work credentials; personal password managers must not hold Company credentials
Storage	Never write passwords down in plain sight, store them in files, chat, tickets or code, or send them by email
Lockout	Account lockout or throttling after **10** failed attempts, with unlock through IT verification or a time delay
Initial passwords	Issued only through a secure channel and changed on first login; vendor default credentials are changed before any system goes live
Passkeys	Passwordless sign-in with passkeys is preferred where supported

---

3.3 Joiner, Mover and Leaver Access Lifecycle

Purpose. To provision access on time and remove it promptly when people join, change roles or leave.

Scope. Employees, contractors, interns, temporary staff and service providers with access.

Joiners

Step	Owner	Timescale
HR confirms start date and role in the HRIS, which triggers the IT ticket	HR	At least **5 business days** before start
Account created in the IdP; standard role access assigned; device ordered, imaged and enrolled	IT	Ready by **day 1**
Manager requests any additional access (with data-owner approval)	Manager	Before start where possible
User completes identity verification, MFA enrollment, acknowledgement (Appendix A)	New starter	Day 1
Mandatory security training completed (see 9.1)	New starter	Within **30 days** of hire (before access to Restricted data is granted where possible)

Access to production systems and Restricted customer data is **not** part of the standard joiner package. It requires a documented business need, manager and owner approval, completion of security training, and, for production, a minimum onboarding period set by Engineering.

Movers (transfers, promotions, role or team changes)

- HR notifies IT of the change no later than the effective date.
- The manager confirms which access is still needed. IT **removes access no longer required within 2 business days** and adds new access through the standard approval process.
- Access is not simply accumulated; the old role's access is revoked as part of the move (avoiding "privilege creep").

Leavers

Situation	Requirement
Voluntary departure	HR notifies IT as soon as the last day is confirmed. All access is disabled **at the end of the employee's last working day** (or earlier, if HR and the manager agree).
Involuntary termination	HR alerts IT and Security **before the meeting**. Access to all systems is disabled **at the time of, or immediately after, notification**, and sessions and tokens are revoked.
Devices	Returned per HR 9.4. Lost or unreturned devices are remotely locked and wiped.
Data	The manager reviews and takes over files and mailbox content; IT preserves accounts and data for a retention period (default **30 days** for the mailbox and personal drive, longer under a legal hold) and then deletes them under 2.5. Backups of a departed user's data for a department are provided on request to the manager.
Accounts and secrets	Service accounts, API keys, shared secrets and admin credentials the person knew or owned are rotated within **2 business days** for privileged staff and within **10 business days** otherwise.
Third-party accounts	Non-SSO SaaS accounts are removed by the application owner within **5 business days**.

- **Contractors and temporary staff** receive access with a fixed end date that matches their contract. Access expires automatically unless renewed (see 8.2).
- HR provides IT a weekly list of active workers for reconciliation. IT reconciles IdP accounts against the HRIS **monthly** and investigates any orphaned accounts within 5 business days.
- Appendix B has the checklists.

3.4 Privileged Access

Purpose. To keep the most powerful accounts to a minimum and tightly controlled.

- **Separate accounts.** Administrators use a separate privileged account for admin tasks and their normal account for email and browsing. Privileged accounts must not be used to read email or browse the web.
- **Just-in-time.** Standing administrator rights are avoided. Elevated cloud, database and production access is granted **just in time**, with approval, for a **limited period (default 4 hours, maximum 24 hours)**, and automatically expires.
- **Approval and logging.** All privileged sessions are logged. Production access to Restricted customer data requires a ticket or incident reference, and is reviewed by Security.
- **Least count.** The number of privileged accounts is kept to the minimum needed and listed in the register that IT maintains. Owners are named.
- **Break-glass accounts.** Emergency accounts are sealed in the secrets vault, protected by hardware keys held by at least two people, monitored with alerts on any use, and reviewed after every use.
- **Vendor and default accounts.** Vendor-supplied or default accounts are disabled or renamed, with credentials changed and stored in the vault.
- **Service accounts.** Each has an owner, purpose and documented permission set; uses secrets from the vault or workload identity (not human credentials); and is reviewed at least every 6 months.
- **Privileged staff obligations.** Administrators may use their access only for their assigned duties. Accessing customer or employee data out of curiosity is a serious policy violation, whatever the technical ability to do so.

3.5 Access Reviews

Purpose. To confirm access remains appropriate and to catch errors.

Scope	Frequency	Reviewer
Privileged accounts (cloud admin, production, database, IdP admin)	**Quarterly**	Security with system owner
Production systems and Restricted-data applications	**Quarterly**	System or data owner
Financial and HR systems (SOX-style controls)	**Quarterly**	System owner and Finance/HR lead
All other business applications and SaaS	**Semi-annually**	Application owner
Source-control organization and repository permissions	**Semi-annually**	Engineering leaders
Service accounts and API keys	**Semi-annually**	Owner with Security
Third-party and contractor access	**Quarterly**	Sponsor and Security

- Reviewers must certify each access as still needed, or mark it for removal. Removals are executed within **5 business days** of review completion.
- IT runs the process, tracks completion, and escalates overdue reviews to the reviewer's department head after **10 business days**. Evidence is retained for **7 years** (see 2.5).
- Additional reviews are run after a reorganization, acquisition or security incident.

3.6 Secrets and Cryptographic Key Management

Purpose. To protect credentials, tokens and keys that grant access to systems and data.

- **No secrets in code.** Passwords, API keys, tokens, private keys and connection strings must not be hard-coded, committed to repositories, pasted into tickets or chat, or stored in wikis. Secret scanning is enabled on all repositories and CI pipelines, and detected secrets are treated as compromised: **revoked and rotated within 24 hours** (immediately for Tier 0 systems).

- **Secrets vault.** Secrets are stored in the Company-approved secrets manager or the cloud provider's key management service, with access by role, audit logging and versioning. Workloads should obtain short-lived credentials (workload identity) rather than long-lived static keys.
- **Rotation.** Long-lived secrets are rotated at least **every 90 days** (Tier 0 systems) or **every 12 months** (others), on suspected compromise, and when someone who knew them leaves.
- **Encryption keys.** Managed in a key management service or hardware security module; separation of duties between key administrators and data users; key access logged; keys backed up securely; customer-managed keys follow the contract. Keys are retired and destroyed at the end of their life under documented procedure.
- **Certificates.** Inventoried with owners and expiry dates; renewal is automated where possible; alerts fire **30 days** before expiry. Self-signed certificates in production require an exception.

Part 4 – Acceptable Use and End-User Computing

4.1 Acceptable Use of Company Systems

Purpose. To set clear technical rules for using Simtora technology. HR 1.9 sets the conduct expectations, and the two are read together.

Scope. All users of Company systems, accounts, networks and devices, wherever they are.

Expected use

- Company systems exist for Company business. **Reasonable, limited personal use** is allowed if it does not interfere with work, consume significant resources, cost the Company money, break policy or law, or create risk.
- Users must comply with software licenses and the rights of others.

- Users must **report** suspected security incidents, lost devices and phishing immediately (see 7.4).
- Users must keep their devices and accounts secure and follow the rules in this manual.

Prohibited use

Users must not:

- Access, or try to access, systems, accounts or data without authorization; probe, scan, test or attack Company or third-party systems, except as part of authorized security testing approved in writing by the CISO.
- Bypass, disable or tamper with security controls, including endpoint protection, device management, VPN/zero-trust agents, content filters, logging or MFA.
- Install unapproved software, browser extensions or "agents" on Company devices that could exfiltrate data or weaken security, or use tools to hide activity.
- Copy, upload or forward Confidential or Restricted data to personal email, personal cloud storage, personal messaging accounts, unapproved AI or SaaS tools, or removable media, except where allowed by 2.1 and 4.7.
- Create or use unauthorized network services, hotspots that bridge Company networks, proxies or anonymizers to bypass controls.
- Mine cryptocurrency, run personal servers, or use Company resources for personal business or financial gain.
- Access, store or share illegal, sexually explicit, hateful, violent or harassing content; or send content that is harassing, discriminatory, defamatory, or infringes copyright (see HR 3.2).
- Share credentials, tokens or MFA codes, or use another person's account.
- Impersonate others, spoof email or send bulk, unsolicited messages.
- Use Company systems to interfere with legally protected activity or with the exercise of legal rights, including employee rights to discuss working conditions.

Access to restricted content for legitimate work

Security research, testing malware samples, or reviewing offensive content for trust-and-safety work may need exemptions. These must be agreed in advance by the manager and Security, run in isolated environments, and documented.

Consequences

Violations may lead to restricted access, corrective action up to and including termination (HR 2.3), termination of contractor engagements, and referral to law enforcement where the law has been broken. Users who report their own mistakes promptly will be treated fairly.

4.2 Company Devices and Endpoint Standards

Purpose. To ensure every device that can reach Simtora data is known, managed and protected.

Baseline requirements for all Company laptops, desktops and phones

Control	Requirement
Ownership and enrollment	Purchased or approved by IT; enrolled in the mobile device management (MDM/UEM) platform before use
Disk encryption	**Full-disk encryption on** (BitLocker/FileVault or equivalent); recovery keys escrowed with IT
Operating system	A supported version; updates applied per 5.6
Endpoint protection	Endpoint detection and response (EDR) agent running and reporting; anti-malware definitions current
Screen lock	Automatic lock after **10 minutes** (laptops) or **2 minutes** (phones); password, PIN or biometric to unlock
Firewall	Host firewall enabled
Local administrator rights	**Not granted** by default. Engineers who need admin rights for a task may request just-in-time elevation or a documented exception
Software installation	

- **Special environments.** Engineering, SRE and Security staff may use developer tooling (containers, virtual machines, local servers) subject to the Engineering standard; production credentials must never be stored on a laptop in unencrypted form.
- **Kiosks and shared devices** (conference rooms, labs) use restricted, non-privileged accounts, wipe sessions after use, and are patched by IT.
- **Travel.** Before international travel, users tell IT so it can advise on risk (for example, high-risk countries may require loaner devices). Devices are never left unattended and never checked in luggage.
- **Loss, theft or suspected compromise.** Report within **1 hour** (see 7.4). Do not try to recover a stolen device yourself. IT will lock and, if necessary, wipe it.

4.3 Personal Devices (BYOD) and Mobile Device Management

Purpose. To allow flexibility with personal phones and tablets while keeping Company data safe.

Policy.

- **Allowed.** Personal **phones and tablets** may access Company email, chat, calendar and approved applications, only if enrolled in MDM (or app-level management for the Company apps) and compliant with the security baseline.
- **Not allowed.** Personal **laptops and desktops** must not be used to access Confidential or Restricted data or production systems. Where a personal computer must be used briefly (for example, a lost laptop), IT provides a virtual desktop or browser-only access that prevents download of data.
- **Baseline for enrolled personal devices.** Supported OS version and current updates, screen lock with PIN/biometric, device encryption, no jailbreak or root, and Company apps kept in a managed container or work profile.
- **Company control.** Simtora may remove Company data and Company apps from an enrolled device (selective wipe), enforce a passcode, and block a non-compliant device. Simtora **does not** access personal photos, messages, browsing, location or personal apps, and does not do a full wipe of a personal device except with the owner's consent (for example, where the owner asks for it after loss).

- **Cost.** Employees who use a personal phone for work may receive the connectivity stipend under HR 7.4 where eligible. Simtora does not otherwise reimburse personal-device costs.
- **Departure.** Company data and apps are removed at separation. The employee's personal data is not touched.
- **Loss or theft.** Report within **1 hour**. IT will perform a selective wipe.
- **Opt-out.** Anyone who does not want to enroll a personal device may ask IT for a Company-issued phone if their role requires mobile access, or go without mobile access to Company data.

4.4 Email, Messaging and Collaboration Tools

Purpose. To make sure communication tools are used safely and professionally.

Scope. Company email, chat, video conferencing, shared drives, wikis, project trackers and any other collaboration tool.

Rules

- Use **Company accounts** for all Company business. Do not use personal email or personal messaging apps for Company matters, and do not forward Company email to personal accounts.
- **Business records.** Messages are business records and may be retained, reviewed or produced in legal proceedings (see 2.5 and 4.8). Write accordingly.
- **Sensitive data.** Do not send Restricted data (for example, credentials, customer personal data or health data) by email or chat. Use approved secure sharing (links with expiry and access control) or the vault.
- **External sharing.** Files shared outside Simtora must be shared with named recipients, with expiry where possible. Sharing links that are open to "anyone" are not permitted for Internal or higher classification data.
- **Disclaimers.** External email carries the standard Company confidentiality footer added by the email gateway.
- **Mass emails.** Messages to all staff need the approval of the sender's department head and may be posted by Internal Communications; users must not email "all staff"

without approval.

- **Newsletters and subscriptions.** Business-related subscriptions using Company email are fine; personal subscriptions should use a personal account.
- **Professional conduct.** No harassing, discriminatory, obscene, defamatory or chain messages (see HR 1.9, 3.2). Use "reply all" and priority flags sparingly.
- **Auto-replies.** For more than three working days out of office, set an out-of-office reply that names an alternate contact.
- **Meetings and recordings.** Record or transcribe meetings only with notice to participants and in line with state consent laws. Recordings are stored in approved locations and follow the retention schedule.
- **Channel hygiene.** Private channels or groups for sensitive topics must have an owner and follow the access rules in Part 3. Channels are archived when inactive for 12 months.

Email security controls (IT)

- Inbound mail is scanned for malware, phishing and spoofing; risky attachment types (for example, executable or script files) are blocked or sandboxed.
- The Company domain uses SPF, DKIM and DMARC (enforced at "reject"), with reports monitored.
- Attachment size limits are set by IT (currently **25 MB**) and large files are shared through approved storage.
- Users report suspected phishing with the one-click "Report phish" button. Reports are triaged by Security within **1 business hour** during support hours.
- Access to another person's mailbox is restricted and approved by HR or Legal, and logged (see 4.8).

4.5 Approved AI Tools and AI Governance

Purpose. To let Simtora and its employees benefit from AI tools while protecting data, intellectual property and people. This section supplies the technical governance behind HR 1.9.

Scope. Any AI tool, model, agent, assistant or service, including generative AI chat, code assistants, coding agents, transcription tools, AI features embedded in SaaS, and AI systems Simtora builds or offers.

Approved tools

- IT Security and Legal maintain the **Approved AI Tools list** on the intranet, showing for each tool: permitted data classes, who may use it, plan or tenant required (for example, an enterprise tenant with no training on Company data and defined retention), and any special conditions.
- An AI tool must not be used with Company data until it appears on the list. To request a new tool, submit a review under 2.3. The review adds AI-specific checks: whether inputs and outputs are used to train models; data retention and location; access controls and SSO; sub-processors; IP and indemnification terms; and security of agent and plugin capabilities.

Data rules

Data class	Approved enterprise AI tools	Unapproved or personal AI tools
Public	Allowed	Allowed
Internal	Allowed	Not allowed
Confidential (including source code)	Allowed only if the tool is approved for that class	Not allowed
Restricted (customer data, personal data, credentials, keys)	**Not allowed** unless the tool is specifically approved for Restricted data by the CISO and General Counsel	**Never**

Never put credentials, secrets or private keys into any AI tool.

Use requirements

- **Human accountability.** A qualified person must review AI output before it is used, shipped or sent externally. The user remains responsible for accuracy, licensing,

security and bias.

- **Code.** AI-generated code follows the same review, testing, scanning and licensing rules as human-written code (see Part 6). Engineers must not accept generated code they do not understand into production. Code assistants must run under approved settings (for example, with public-code matching filters where available, and without access to production secrets).
- **Agents and automation.** AI agents that can take actions (run commands, access repositories, send messages, call APIs) must use dedicated identities with least privilege, be approved by Security, and have activity logged. No AI agent may hold production write access without human approval for each high-impact action, unless approved by the CISO and a named owner.
- **Intellectual property.** Do not knowingly submit third-party copyrighted or confidential material to AI tools without rights to do so.
- **Decisions about people.** Do not use AI tools to make or materially support decisions on hiring, promotion, pay, discipline or termination without HR and Legal approval and human review (see HR 1.9).
- **Disclosure.** Where a customer contract or law requires it, Simtora discloses AI use and does not use customer data to train models without permission.
- **Meeting assistants.** AI note-takers and transcription bots may join meetings only if approved, with notice to all participants and, for external meetings, consent from other parties.

AI in Simtora products

AI features Simtora builds or embeds follow a documented review by Engineering, Security, Legal and Product before launch: purpose and risks, data used to train or ground models, testing for accuracy, bias and safety, prompt-injection and data-leak resistance, human oversight, monitoring, and a process to handle incidents. Applicable law and customer requirements (for example, state AI-related laws and the NIST AI Risk Management Framework as a guide) inform the review. The Head of IT / CISO and General Counsel maintain the AI governance standard and inventory of AI systems.

4.6 Remote Work and Workspace Security

Purpose. To keep information safe wherever people work. Eligibility and arrangements for hybrid and remote work are in HR 5.2.

- **Approved devices only.** Work on Company data only from Company-managed laptops (or enrolled phones and tablets under 4.3).
- **Networks.** Home networks should use WPA2 or WPA3 with a strong passphrase and updated router firmware, and the router's default admin password must be changed. Public or shared Wi-Fi (cafés, airports, hotels) may be used only with the Company's always-on VPN/zero-trust client active; avoid sensitive work in public where possible.
- **Physical privacy.** Don't leave screens visible to others; use a privacy screen in public; take calls with confidential content where they cannot be overheard; never leave laptops unattended in vehicles or public places.
- **Family and guests.** No one else may use a Company device or see Restricted information.
- **Printing at home.** Do not print Confidential or Restricted information at home (see 4.7).
- **Secure storage.** Lock devices, notebooks and hardware keys when not in use.
- **Fully remote employees** follow the same rules and receive the same support. IT may require additional checks (for example, home-network review, hardware keys) for roles with access to Restricted data.
- **Working from outside the country of employment.** Employees may work from their country of employment (the United States, Pakistan, Germany, France, Australia or the United Kingdom). They must not work from any other country without approval from their manager, HR and IT (and Legal and Tax for periods over 20 working days a year; see SIM-HR-002, Part 1.9), because of legal, tax, export-control and security considerations. Devices must not travel to embargoed or sanctioned countries under any circumstances.
- **Conferencing.** Use approved conferencing tools with waiting rooms or passcodes; check attendee lists before sharing sensitive content; do not share screens with unrelated windows or notifications visible.

4.7 Removable Media, Printing and Physical Documents

- **Removable media.** USB storage and other removable media are **blocked by default** on Company devices by endpoint controls (data loss prevention). Exceptions (for example, for lab work, diagnostics or customer-requested transfers) require IT approval, use encrypted media provided by IT, and are logged. Never plug in unknown USB devices found or received.
- **Printing.** Print only when necessary. Retrieve printouts immediately. Confidential or Restricted printouts must be locked away or shredded (see 2.4). Printers are on the managed network with updated firmware and secure release where available.
- **Clear desk.** When away from the desk at the end of the day, or when a workspace is shared, secure laptops, notebooks, printouts and hardware keys in locked drawers or cabinets. This is stricter for shared or hot-desk areas. (Workplace security is also covered in the Facilities and Office Administration Manual, SIM-FAC-001, Part 2.)
- **Clear screen.** Lock the screen (Windows+L or Ctrl+Cmd+Q) whenever you step away. Shut down or sign out for extended absences.
- **Whiteboards.** Erase whiteboards containing Confidential or Restricted content after meetings and before leaving a room.

4.8 Monitoring and Privacy

Purpose. To explain what Simtora monitors, why, and how the information is protected. This section implements the notice in HR 1.9.

- **What is monitored.** Company systems, accounts and devices, and the data on them, are Company property. To protect security, ensure compliance, keep systems reliable and investigate misconduct, Simtora may log, monitor, access, review, copy and retain activity and content, including network traffic, email and chat metadata and content, web access, file access and transfers, endpoint activity and application logs, to the extent the law permits.
- **Tools.** Typical tools include EDR, email and web security gateways, data loss prevention, SIEM logging, device-management inventory and cloud audit logs. Monitoring is automated first; humans review content only when triggered by an alert, incident, legal need or authorized investigation.
- **No expectation of privacy** in Company systems, subject to the limits below.

- **Notice.** Users acknowledge this policy at onboarding (Appendix A). Where state law requires specific notice of electronic monitoring (for example, New York, Connecticut, Delaware), this section and HR 1.9 serve as that notice, and the acknowledgement is kept on file.
- **Limits.** Simtora will not monitor personal accounts or personal devices except as they interact with Company systems. Monitoring will not be used to interfere with legally protected activity, such as employee communications about pay or working conditions, complaints to government agencies or whistleblowing. Personal data accessed in the course of monitoring is used only for the stated purposes.
- **Who may look.** Access to individual employees' content (for example, another person's mailbox, files or chat) requires written approval from the **General Counsel and the Chief People Officer** (or, for security incidents, the CISO with Legal). Requests, approvals and access are logged. Access by IT staff without approval is a serious violation. Routine security tools acting automatically do not need per-instance approval.
- **Location and biometrics.** Simtora does not track employee location by GPS except on Company-owned devices for a defined business purpose (such as device recovery), with notice. Any use of biometric data is reviewed by Legal first and follows state laws.
- **Retention of monitoring data.** Per 5.5 and 2.5. Access is limited to Security, IT operations and Legal on a need-to-know basis.
- **Investigations.** Forensic collection from devices or accounts is carried out by Security under the direction of Legal or HR, following chain-of-custody practices.

4.9 Website, Domains and Public Digital Presence

Purpose. To ensure Simtora's public websites and digital properties are accurate, secure and consistent.

- **Ownership.** Marketing owns website content and brand; IT owns hosting, domains, DNS, certificates and security; Engineering owns product websites and customer-facing applications.
- **Content.** All content must be accurate, lawful, appropriate and current. It follows the Company's brand guidelines and is reviewed **every quarter** by Marketing. Legal

approves claims about security, compliance or performance (for example, statements about certifications).

- **Domains and DNS.** All Company domains are registered in the Company's name under IT-controlled accounts with MFA, registrar lock and auto-renew. New domains and subdomains need IT approval. Dangling DNS records are removed to prevent takeover. DNSSEC is used where supported.
- **Security.** Websites use HTTPS with modern TLS (see 5.4), security headers, web application firewall and DDoS protection where appropriate, and are included in vulnerability scanning and penetration tests (see 9.3). Third-party scripts, analytics and tags need a privacy and security review.
- **Privacy.** Websites present accurate privacy notices and honor opt-out signals (such as Global Privacy Control) and cookie choices as required by state law (Legal reviews).
- **Social media.** Official Company accounts are registered to Company email addresses with MFA and at least two administrators, and are managed by Marketing. Employees speak for themselves, not for the Company, unless authorized. Personal social media use is addressed in HR 1.7 and must not disclose Confidential information.
- **Accessibility.** Public digital properties should meet WCAG 2.1 AA.

Part 5 – Network, Infrastructure and Cloud Security

5.1 Network Security

Purpose. To protect Company networks and the services on them from unauthorized access and attack.

Scope. Office networks, cloud networks, VPN and zero-trust access, wireless, and connections to customers and vendors.

- **Architecture.** The network security architecture is documented, reviewed at least annually, and reviewed by an external specialist when major changes are made or at

least every two years. Changes to the architecture need Security approval and go through change management (6.4).

- **Zero trust.** Access to internal applications is based on user identity, device health and context, not on network location. Being on the office network does not by itself grant access.
- **Segmentation.** Production, staging, development, corporate IT, guest and IoT/building networks are separated. Production networks are not reachable from the office or the public internet except through controlled, logged paths. Customer environments are logically isolated from each other.
- **Perimeter controls.** Firewalls or security groups follow "default deny"; only required ports and protocols are open, each with a documented owner and purpose. Rules are reviewed **every 6 months**, and unused rules are removed. Intrusion detection or prevention and DNS filtering are enabled at gateways and in cloud environments. Egress from production is restricted to known destinations where feasible.
- **Remote access.** Remote access to internal resources uses the Company VPN or zero-trust access client with MFA and a compliant managed device (see 3.2, 4.2). Split tunneling is allowed only for approved low-risk destinations. Direct administrative access from the internet (for example, SSH or RDP open to the public) is **prohibited**; use bastion, session-manager or zero-trust brokers.
- **Wireless.** Office Wi-Fi uses WPA3-Enterprise (or WPA2-Enterprise) with certificate or SSO authentication. Guest Wi-Fi is isolated, has no access to Company resources, and requires the terms of use. Rogue access points are detected and removed.
- **Network devices.** Routers, switches, firewalls and access points are hardened to standard baselines, use unique admin credentials stored in the vault, are patched under 5.6, and their configurations are backed up and version-controlled.
- **Documentation.** Network diagrams, IP addressing and data flows are maintained and updated within **5 business days** of a change.
- **Third-party connections.** Connections to customers, vendors and partners are approved by Security, documented, limited to what is needed, encrypted, and reviewed at least annually.
- **DDoS and availability.** Internet-facing services use DDoS protection and rate limiting appropriate to their criticality.
- **Testing.** External and internal network penetration tests occur at least annually (see 9.3).

5.2 Cloud and Infrastructure Standards

Purpose. To ensure cloud services and infrastructure are configured securely and consistently.

Scope. Public cloud (IaaS, PaaS, SaaS), containers, Kubernetes, serverless, CI/CD infrastructure and any Company-run servers.

- **Approved providers.** Only cloud providers and regions approved by IT Security and Legal may be used. IT decides the provisioning and architecture of cloud services, including how IaaS, PaaS and SaaS are used.
- **Account structure.** Separate cloud accounts, subscriptions or projects for production, non-production, security tooling and shared services. The root or owner account of each cloud tenancy is protected with hardware-key MFA, is not used for daily work, and its credentials are held under dual control.
- **Infrastructure as code.** Infrastructure is defined in version-controlled code, changed through reviewed pull requests and deployed through pipelines. Manual changes to production ("click-ops") are limited to emergencies and must be reconciled back to code within **2 business days**.
- **Guardrails.** Security guardrails (policies as code, service control policies, cloud security posture management) block or alert on: publicly accessible storage or databases, unencrypted storage, unrestricted inbound rules, missing logging, unapproved regions and unapproved services. Critical misconfigurations are fixed within **24 hours**.
- **Hardening.** Servers, containers and images are built from hardened baselines (for example, CIS benchmarks), scanned for vulnerabilities, and rebuilt rather than patched in place where possible. Only signed images from the approved registry may run in production.
- **Identity.** Workloads use workload identity and roles rather than long-lived keys (see 3.6). Human console access uses SSO and just-in-time roles (see 3.4).
- **Tagging.** Every resource is tagged with owner, team, environment, data classification and cost center.
- **Shared responsibility.** Owners must understand which controls the provider handles and which remain Simtora's responsibility, and record this in the design.

- **Standard configurations.** IT and Engineering define standards for servers, endpoints, network devices, printers and connectivity across offices and cloud environments. IT scans devices and cloud resources periodically for unauthorized software or drift and removes it.
- **Multi-tenancy.** Product architecture must enforce tenant isolation and be tested for it.
- **SaaS security.** Business-critical SaaS is configured to the IT baseline (SSO/MFA, audit logging, admin roles limited, data sharing controls) and monitored with SaaS security posture tools where available.

5.3 Physical Security of IT Areas and Environmental Controls

Purpose. To protect the small amount of on-premises technology Simtora operates. Most production runs in the cloud, so physical risk is mostly about offices, network closets and devices.

Scope. Network rooms and closets, any on-premises server or lab equipment, storage locations for spares and media, and office areas where IT equipment is used. Workplace security in general is set in the Facilities and Office Administration Manual (SIM-FAC-001, Part 2).

- **Secure areas.** IT designates as "secure areas" any network room, wiring closet, on-premises server room, lab or equipment store. Secure areas are locked with badge, key or other access control and closed when unattended.
- **Access.** Only authorized people who need access for their role may enter. The list of people with access is reviewed **every 6 months** by IT and Facilities, and removed the day someone leaves or no longer needs it.
- **Visitors and vendors.** Visitors and contractors (for example, cleaners, electricians, auditors) enter secure areas only for a valid purpose, are signed in, and are **accompanied by an authorized person at all times**.
- **Notices and prohibitions.** Secure areas display signage. Food, drink, smoking, vaping, storage of unrelated materials and unauthorized equipment are prohibited.
- **Cabling and equipment.** Cable terminations and patch panels are documented and labeled. Equipment is installed in racks with locks where practical.

- **Environmental controls** (where equipment is on-site): temperature and humidity are kept within manufacturer specifications and monitored with alerts; equipment is protected with uninterruptible power supply and surge protection sized to the load, with redundant cooling where practical; fire detection and appropriate suppression are installed, and water-leak sensors are used where there is risk. Environmental controls are tested at least annually.
- **Office design.** Facilities consults IT before opening a new office or renovating an existing one, so that network room layout, cabling, power, cooling and access controls are planned.
- **Colocation and cloud data centers.** Where third-party facilities host Simtora equipment, Security reviews their SOC 2 or equivalent physical-security attestations annually (see 8.1).

5.4 Encryption

Purpose. To protect data confidentiality and integrity in transit and at rest.

Area	Requirement
Data in transit	TLS **1.2 or higher** (1.3 preferred) for all internal and external connections carrying Internal or higher data; older protocols (SSL, TLS 1.0/1.1) disabled. Email uses opportunistic or enforced TLS.
Data at rest	Encryption (AES-256 or equivalent) for all Confidential and Restricted data: databases, object storage, backups, laptops, phones, removable media
Customer data	Encrypted at rest and in transit; per-tenant or customer-managed keys where the contract requires
Algorithms	Only current, industry-accepted algorithms and key lengths; deprecated ones (for example, MD5, SHA-1 for signatures, DES/3DES, RC4) are prohibited. Do not create custom cryptography
Keys	Managed per 3.6; stored separately from the data they protect
Mobile and portable devices	Full-disk encryption mandatory (see 4.2)
Post-quantum readiness	Security tracks NIST post-quantum standards and plans for a crypto-agility roadmap for long-lived data
Export controls	Products with encryption features are classified by Legal under the Export Administration Regulations before release (see 8.3)

5.5 Logging, Monitoring and Audit Trails

Purpose. To detect misuse and attacks, and to support investigations, audits and compliance.

- **What is logged.** Owners of information systems define the events and transactions to be logged, with IT. At a minimum: authentication and authorization events (successes, failures, MFA changes); privileged and administrative actions; access to Restricted data; changes to configuration, permissions and code deployment; cloud control-plane

activity; network and firewall events; endpoint and EDR alerts; email and web gateway events; and application security events.

- **Central collection.** Logs from all Tier 0 and Tier 1 systems are sent to the central SIEM/log platform, with time synchronized (NTP) across systems.
- **Protection.** Logs are access-controlled, immutable or tamper-evident, and separated from those who administer the logged system. Only the Security Team and authorized IT staff may view them; changes to logging configuration are alerted.
- **Retention.** Security-relevant logs are kept **at least 12 months**, with the most recent **90 days** immediately searchable. Longer retention applies where law or customer contracts require (see 2.5).
- **Monitoring.** Security monitors alerts **24×7** (through in-house on-call, a managed detection and response provider, or both). Detection use-cases are reviewed at least **quarterly** against current threats. Alerts are triaged per the severity levels in 7.4.
- **Review.** Exceptions and anomalies are escalated to the system owner. Privileged activity logs are reviewed **weekly** (sampling permitted) and admin-access anomalies immediately.
- **Personal data in logs.** Logs must not contain passwords, secrets, or unneeded personal data; developers mask or exclude such data.

5.6 Vulnerability and Patch Management

Purpose. To find and fix weaknesses before they are exploited.

Scanning and discovery

- Authenticated vulnerability scans of servers, endpoints, containers, cloud configurations and applications run **at least weekly** (continuously for cloud and endpoint agents).
- Code, dependencies, container images and infrastructure-as-code are scanned in pipelines (see 6.1).
- External attack surface is scanned continuously. Penetration tests are covered in 9.3.

Remediation timescales

Severity combines vendor score (CVSS), exploitability and asset criticality. Timelines run from the day the vulnerability is confirmed or the patch is released, whichever is later.

Severity	Internet-facing or Tier 0 systems	Other systems
Critical (for example, actively exploited, remote code execution)	**72 hours** (or immediate mitigation within 24 hours if no patch exists)	**7 days**
High	**7 days**	**14 days**
Medium	**30 days**	**45 days**
Low	**90 days**	**Next scheduled maintenance**

- Vulnerabilities on CISA's Known Exploited Vulnerabilities (KEV) list are treated as **Critical** and remediated within the shorter of the above timelines or CISA's due date.
- Items that cannot be fixed on time need a documented exception (see 1.3) with compensating controls and an end date.
- Patches are tested where feasible before rollout, applied in stages, and have a rollback plan; only authorized patches from the vendor are used. Emergency patching uses the emergency change route (see 6.4).
- **Endpoints.** Operating system and browser updates are pushed automatically; laptops must apply critical updates within **7 days** and restart when prompted. Devices that fall out of compliance for more than **14 days** are blocked from Company resources.
- **End-of-life.** Systems and software no longer supported by the vendor are identified in the inventory and replaced or isolated before support ends; unsupported systems in production need an exception.
- **Reporting.** Vulnerability status against these timelines is reported monthly to the Head of IT / CISO and quarterly to the ITSC.

5.7 Malware and Endpoint Protection

- **Coverage.** EDR/anti-malware runs on all servers, laptops and other managed endpoints, with signatures and behavioral detection updated automatically. Users must not disable or tamper with it.
- **Email and web.** Email and web gateways scan for malware, malicious links and attachments; risky file types are blocked or detonated in a sandbox; browsers use safe-browsing protections.
- **Application control.** Execution of unapproved software on managed endpoints is restricted through allow-listing or reputation-based controls, as set out in the endpoint standard.
- **Detection and response.** Malware alerts are triaged as security incidents (see 7.4). Infected devices are isolated from the network immediately and reimaged, rather than "cleaned," where the malware is serious.
- **User responsibility.** Do not open unexpected attachments or links, do not connect unknown devices, and report anything suspicious immediately using the "Report phish" button or **security@simtora.example**. Reporting a mistake quickly is always the right choice.
- **Ransomware.** The backup design (7.2) and the incident playbook (7.4) include ransomware scenarios, and Simtora does not commit to paying ransoms without Legal review, Executive Team approval and consultation with law enforcement and sanctions (OFAC) advice.

Part 6 – Software Development and Change

6.1 Secure Software Development Lifecycle

Purpose. To make sure Simtora's products and internal software are designed, built, tested and released securely.

Scope. All software developed by or for Simtora, including products, internal tools, scripts, infrastructure code, data pipelines and AI features.

Phase	Required security activities
Plan and design	Security requirements captured with the feature; **threat modeling** for new services, major changes and anything handling Restricted data; privacy review where personal data is used (see 2.5); architecture review for Tier 0 changes
Build	Secure-coding standard (for example, aligned with OWASP ASVS and Top 10); approved libraries and frameworks; no secrets in code (3.6); input validation, output encoding, authentication and authorization built-in; least privilege for services
Review	Peer code review by at least one other engineer for every change (two for security-sensitive code); Security review for authentication, cryptography, payment, tenant isolation and similar
Test	Automated static analysis (SAST), dependency and software-composition analysis (SCA), secret scanning, container and infrastructure-as-code scanning on every pull request or build; dynamic testing (DAST) and API security tests on staging for internet-facing services; unit, integration and regression tests
Release	Build only in the trusted pipeline; artifacts signed and stored in the approved registry; release checks pass; change approved under 6.4; software bill of materials (SBOM) generated for products
Operate	Monitoring, logging, alerting and runbooks in place; vulnerability management per 5.6; secure configuration; incident readiness
Retire	Per 6.7

- **Release gates.** A release with an open Critical or High finding that is in the affected code path is blocked unless the Head of Engineering and the CISO approve a time-limited exception (see 1.3).
- **Training.** Engineers complete secure-coding training within **60 days** of joining and annually thereafter (see 9.1).
- **Security champions.** Each engineering team names a security champion who liaises with Security.
- **Bug bounty and disclosure.** See 9.4.

- **Product security.** Engineering maintains a product-security process for customer-reported vulnerabilities, including CVE assignment where appropriate, coordinated disclosure, and customer advisories.

6.2 Source Code, Repositories and Build Pipelines

- **Approved platform.** All Company source code is hosted in the Company's approved source-control organization, with SSO and MFA enforced. Personal or unapproved repository accounts must not be used for Company code.
- **Repository standards.** Every repository has an owner, a documented purpose and a visibility setting. **Public repositories** require approval under 6.3 and a check for secrets and confidential content before publishing.
- **Branch protection.** Default branches are protected: no direct pushes, required pull-request review, required status checks (tests and security scans), signed commits or verified authorship for Tier 0 repos, and no force-push or deletion.
- **Access.** Least privilege by team; write access is limited to contributors; admin rights are limited to a few owners; access is reviewed under 3.5.
- **Build pipeline security.** CI/CD runners are managed, ephemeral and isolated; pipeline configuration is code-reviewed; pipeline secrets come from the vault; third-party actions or plugins are pinned to trusted versions; artifact provenance is recorded; production deploy credentials are available only to the deploy stage.
- **Code ownership and IP.** Company code belongs to Simtora as set in the Confidentiality and Invention Assignment Agreement (HR 1.8). Employees must not copy Company source code to personal repositories, personal machines or unapproved tools, even after leaving.
- **Backups.** Repositories are backed up under 7.2.

6.3 Open-Source Software Policy

Purpose. To enable safe, compliant use of and contribution to open source. This section supplies the open-source policy referred to in HR 1.8.

Using open-source software

- Open-source components may be used if the license is approved, the component is maintained, and it has passed dependency scanning.
- **License categories:**

Category	Examples	Rule
Permitted	MIT, BSD, Apache 2.0, ISC	Use freely with attribution and notices
Restricted	LGPL, MPL, EPL	Use with Legal approval and only in ways that preserve compliance (for example, dynamic linking)
Prohibited in distributed or hosted products without Legal approval	GPL, AGPL, SSPL, "commons clause," non-commercial or unknown licenses	Legal approval required before use

- Engineering maintains an **approved-components list** and the automated SCA tooling enforces it in pipelines. New third-party packages are pinned to specific versions, with lockfiles, and from trusted registries only. Package "typosquatting" and dependency-confusion controls (internal registry, scoped names) are enforced.
- **SBOM and notices.** Engineering generates an SBOM for each product release and keeps license notices current. Customer questions on SBOMs are answered by Product Security.

Contributing to open source

- **On Company time or for Company purposes:** requires manager approval and approval from the head of Engineering and Legal, following the contribution process (license, IP review, security review, code owner). Contributions use a Company identity or a clearly linked identity as directed by Legal.
- **Releasing Company code as open source** requires approval from the CEO or CTO-equivalent (head of Engineering), Legal and Security, and a review that removes

secrets, third-party code conflicts and customer-specific material.

- **Personal contributions on personal time**, using personal equipment and unrelated to Simtora's business, are permitted and should be disclosed if they could overlap with Simtora's products (see HR 1.8).
- **Contributor agreements.** Employees must not accept or sign contributor license agreements on Simtora's behalf.

6.4 Change Management

Purpose. To make changes to production and important systems in a controlled way that reduces outages and security risk.

Scope. All changes to production and Tier 0 and Tier 1 systems, including application releases, infrastructure and network changes, database schema changes, operating-system and platform updates, configuration and permission changes, SaaS changes that affect business processes, and IdP changes.

Types of change

Type	Description	Approval
Standard	Low-risk, repeatable and pre-approved (for example, routine deployment of a tested service through the pipeline, certificate renewal)	Pre-approved template; peer review and passing automated checks
Normal	Any change not covered above	Peer review plus approval by the service owner; higher-risk changes go to the **Change Advisory Board (CAB)**
Emergency	Needed immediately to restore service or fix a critical vulnerability	Verbal or chat authorization from the on-call incident commander or the service owner, with **retrospective documentation within 2 business days**

Requirements

- Changes are requested in the change system (Appendix D lists the fields): description, reason, systems affected, risk and impact assessment, testing evidence, rollback plan, schedule and owner.
- **Impact and risk.** Changes are rated Low, Medium, or High based on scope, criticality, reversibility and customer impact. **High-risk changes** go to the CAB (Engineering, SRE, Security, Support and a business representative), which meets weekly and on demand.
- **Segregation of duties.** The person who writes a change cannot be the only one to approve or deploy it to production; the pipeline enforces peer review and automated checks.
- **Testing.** All changes are tested in a non-production environment that mirrors production as closely as practical before they are released.
- **Scheduling.** Planned changes with customer impact occur in agreed maintenance windows (default: outside business hours, Tuesday–Thursday evenings Eastern time) with notice: **5 business days** for planned customer-visible maintenance where the contract requires. Change freezes apply around critical business periods, published by SRE.

- **Communication.** Affected teams and customers are notified before and after significant changes. The status page is updated for customer-visible work.
- **Post-implementation review.** Failed and emergency changes, and any change that caused an incident, are reviewed, and lessons are recorded.
- **Financial and HR systems** follow the same process, with additional sign-off by Finance or HR for changes to key logic, controls or reports, to support IT general controls (see 1.4).
- **Records.** Change records are kept for **3 years** (7 years for financial-system changes).

6.5 Environments, Production Access and Customer Data in Non-Production

- **Separate environments.** Development, testing/staging and production are separate, with different accounts and credentials. Code moves toward production only through the pipeline.
- **Production access.** Limited to those who need it to operate or support the service (see 3.4). Access is just-in-time, logged and reviewed. Engineers do not deploy from laptops to production; deployments go through the pipeline.
- **No real customer data in development or test.** Non-production environments use synthetic or properly de-identified and masked data. Using production data in non-production requires written approval from the data owner and the CISO, is limited to a defined purpose and period, and is protected at the same level as production. Restricted personal data is never copied to laptops.
- **Customer support access.** Support engineers may view customer data only through approved, logged tools, with the customer's authorization or a valid ticket, and for the minimum time needed.
- **Feature flags and configuration** changes in production follow change management appropriate to their risk.

6.6 Outsourced Development and Software Escrow

- **Contract.** All development or implementation projects done by outside providers are covered by a signed contract that includes confidentiality, security obligations, IP assignment to Simtora (work made for hire or assignment), right to audit, breach notification, subcontracting restrictions, and insurance. Legal reviews the contract.
- **Project management.** Each engagement has a named Simtora manager and provider project lead. Progress and quality are tracked and reported.
- **Security.** External developers follow this manual, including secure development (6.1), access controls (3.3 and 8.2) and code review. Their code is scanned and reviewed like internal code before merge. They access Company systems through Company-issued accounts and devices, or approved secure environments.
- **Escrow.** For business-critical software that Simtora depends on but does not own (for example, a specialized third-party application), the contract includes a **source-code escrow or continuity clause** so Simtora can take over the code if the vendor ceases business or fails to support it. Exceptions need approval by the CISO.
- **Acceptance.** Simtora signs off on deliverables only after testing and security review.
- **Exceptions** to this section are approved by the Head of IT / CISO.

6.7 Software Retirement and Decommissioning

- IT and Engineering review the application portfolio at least **annually** to decide whether to retire software. Factors include obsolescence, lack of vendor support, cost, weak security features, resource use, availability of better alternatives and technology change.
- Retirement decisions are recorded, and responsibility is assigned to named owners to remove software and integrations, revoke credentials, close cloud resources, remove DNS records and update inventories.
- **Data.** Confidentiality and integrity of data stored in retired systems are maintained; data is migrated, archived or deleted according to retention rules and legal holds (see 2.5), and customer contract terms.
- **Archiving.** Retired software and its configuration are archived so it can be restored for legal, audit or emergency needs for the retention period.
- Customers are given notice as their contracts require, before a product or feature is retired.

Part 7 – Operations and Resilience

7.1 IT Operations and Configuration Management

- **Defined responsibilities.** Responsibilities for operating systems, networks, cloud platforms and facilities are formally assigned to named teams. Administrators take on their duties only after formal authorization and training in the security requirements of their tasks.
- **Runbooks.** Key operational tasks have documented, tested runbooks, followed consistently.
- **Configuration management.** System configurations are recorded in a configuration management database (CMDB) or in code, and reviewed regularly. Drift from approved baselines is detected and corrected. Unauthorized software and hardware are detected and removed.
- **Planned disruptions.** Planned outages are scheduled outside business hours where possible, and users and customers are told the expected duration well in advance (see 6.4).
- **Data archival.** Older data is archived on a schedule that balances performance, cost, legal and user needs. Archived data is stored securely, retains integrity, and is restorable per the backup policy (7.2). Retention follows 2.5.
- **Capacity and monitoring.** See 7.6.
- **Documentation.** Infrastructure, network, application and runbook documentation is kept current and available to on-call staff even if primary systems are down.

7.2 Backup and Restoration

Purpose. To ensure data can be recovered after loss, corruption, ransomware or disaster.

Backup requirements by tier

Tier	Examples	Backup frequency	Retention	Recovery targets
Tier 0	Production databases, source control, IdP configuration, secrets vault, infrastructure code state	Continuous or point-in-time recovery plus daily snapshots	35 days online; monthly archives for 12 months	**RPO 15 minutes, RTO 4 hours**
Tier 1	Email and collaboration, finance and HR systems, ticketing, CI/CD	Daily	35 days	**RPO 24 hours, RTO 1 business day**
Tier 2	Internal tools, non-critical SaaS	Daily or weekly	30 days	**RPO 24 hours, RTO 3 business days**

RPO (Recovery Point Objective): maximum acceptable data loss. RTO (Recovery Time Objective): maximum acceptable time to restore. Customer contracts may require stricter targets, which then apply to that service.

- **Owners define requirements.** Data and system owners, with IT, document backup frequency, type (full, incremental), retention, and recovery objectives for each system. Backup requirements are kept current and changes are updated within one business day of approval.
- **What is backed up.** Application databases, system and configuration data, source code and infrastructure-as-code, firewall and network configurations, identity and secrets-vault data, and SaaS data that the vendor does not adequately protect (for example, third-party backup of email, files, source-control organizations and ticketing).
- **The 3-2-1 rule.** At least three copies, on two different media or services, with one copy **offsite/in a separate cloud account or region** under Company control with comparable security.
- **Immutability and separation.** Backups are encrypted (see 5.4), protected from deletion or alteration by ransomware or a compromised admin (immutable storage or

separate credentials with dual approval), and administered separately from the systems they protect.

- **Responsibility.** IT assigns named teams to run and monitor backups and alert on failure. Failures are corrected within **1 business day**.
- **Restore testing.** Backups are test-restored: Tier 0 systems **at least quarterly**, Tier 1 **at least semi-annually**, Tier 2 **annually**, with results documented (time to restore, success, gaps). A backup that has not been tested is not considered reliable.
- **Departed users.** Data of exiting users is backed up and transferred to the requesting department on request (see 3.3).
- **Media handling.** Backup media (where used) is labeled, stored securely with controlled access, transported under chain of custody, and destroyed securely at end of life (see 2.4).
- **Individual users.** Users must save work to approved storage and not rely solely on local disks.

7.3 Business Continuity and Disaster Recovery

Purpose. To keep or quickly restore critical technology services during and after disruption.

- **Business impact analysis.** IT and business owners perform a business-impact analysis at least annually to confirm the tiers and targets in 2.2 and 7.2.
- **Disaster recovery (DR) plans.** IT and SRE maintain DR plans for every Tier 0 and Tier 1 service, covering: scenarios (region outage, provider outage, ransomware, loss of the IdP, loss of key people, loss of an office), recovery steps and order, roles and contact lists, alternate work arrangements, vendor dependencies, and communications templates (internal, customer, regulator).
- **Multi-region / resilience.** Tier 0 production services are architected for high availability across availability zones, and have a documented and tested recovery path to a second region as required by customer commitments.
- **Named owner.** A named individual (the DR lead) is responsible for the plans. Plan changes go through change control, and updated plans are distributed to all who need them.
- **Testing.** Plans are tested at least **annually**: a tabletop exercise for all plans, and a technical failover or restore test for Tier 0 services. Results, gaps and remediation are

reported to the ITSC. Lessons learned update the plan within **30 days**.

- **Work-from-anywhere continuity.** Because the workforce is hybrid, an office closure does not by itself interrupt work. Procedures ensure that critical roles can work remotely with approved devices and that alternate communication channels exist if the primary tools fail (for example, an out-of-band messaging and conferencing option).
- **Communication.** Customer-facing outages are communicated through the status page and account teams per the incident process (7.4). Facilities-related emergencies (fire, evacuation, severe weather) follow the Facilities and Office Administration Manual (SIM-FAC-001, 6.2 and 6.7) and HR 4.3.
- **Pandemic and staff-loss planning.** Critical roles have trained backups, and runbooks let another qualified person operate a service.

7.4 Security Incident Management

Purpose. To detect, contain, investigate and learn from security incidents, and to meet legal and contractual notification duties.

Scope. Any event that actually or potentially compromises the confidentiality, integrity or availability of Simtora or customer information or systems, including malware, unauthorized access, phishing that succeeds, lost or stolen devices, data exposure, insider misuse, vendor compromise and denial-of-service.

Everyone's duty to report

Report suspected incidents immediately, and no later than 1 hour after you become aware of them for lost or stolen devices, by any of:

- **security@simtora.example**
- The **#security-incident** channel or the "Report an incident" form
- The **IT Helpdesk** (it@simtora.example, or the on-call number for urgent, out-of-hours matters)
- The "Report phish" button for suspicious emails

Do not try to investigate, delete evidence, confront suspected wrongdoers or pay any demand yourself. **No employee will be penalized for reporting an incident or a mistake in good faith.** Retaliation is prohibited (see HR 3.2, 3.3).

Severity levels

Severity	Definition	Response start	Executive notification
SEV 1 – Critical	Confirmed or likely breach of customer or Restricted data; ransomware; production outage of Tier 0 services; compromise of privileged or IdP credentials	Immediately (within **15 minutes**, 24×7)	CEO, General Counsel and CFO within **1 hour**
SEV 2 – High	Serious but contained incident; significant malware; suspected compromise of an employee account with sensitive access; partial outage	Within **1 hour**	Executive Team within **4 hours**
SEV 3 – Medium	Limited impact, single device or user, policy violation with security impact	Within **4 business hours**	Head of IT / CISO
SEV 4 – Low	Minor events, false positives, informational	Next business day	Reported in metrics

Incident lifecycle

1. **Detect and report.** Through monitoring (5.5), users, customers, vendors or researchers (9.4).
2. **Triage.** The on-call security responder classifies severity within 15 minutes for suspected SEV 1/2 and opens an incident record. An **incident commander** is named for SEV 1 and SEV 2.
3. **Contain.** Isolate affected systems and accounts; revoke credentials and sessions; block malicious indicators; preserve evidence (logs, images, timelines). Containment decisions that affect customers need incident-commander approval.

4. **Investigate and eradicate.** Determine cause, scope and data involved. Remove the threat and fix root causes.
5. **Recover.** Restore systems from clean sources, monitor for recurrence, and confirm normal service.
6. **Notify.** Legal (see below) and Communications.
7. **Post-incident review.** For SEV 1 and 2, a blameless review is held within **10 business days**, with a written report, root causes, and tracked corrective actions with owners and dates. Reports go to the ITSC and, for material incidents, the Audit Committee.

Legal, regulatory and customer notification

- **Legal decides.** The General Counsel leads determination of whether notice is required and to whom, working with the CISO. No one else may notify customers, regulators, media or law enforcement without Legal approval, except in an emergency threatening life or safety.
- **Timing.** Simtora will notify affected customers as promptly as possible and within the period in the customer contract (typically **72 hours or less** from confirmation of a breach affecting their data). State breach notification laws are met, which generally require notice to individuals without unreasonable delay and to state regulators in specified cases; where the law sets a shorter deadline it applies. If Simtora is subject to SEC or other sectoral incident-disclosure rules, Legal and the CFO manage those filings within the required time (for example, a Form 8-K determination within **four business days** of materiality determination, where applicable).
- **Law enforcement.** Legal decides on contacting the FBI, CISA or local law enforcement; the CISO maintains those contacts.
- **Cyber insurance.** Finance and Legal notify the carrier per policy terms, usually immediately upon discovery of a SEV 1 event.
- **Evidence.** Incident records, forensic images and communications are preserved under legal hold as instructed by Legal.

Readiness

- The **Incident Response Plan** and playbooks (for example, ransomware, business email compromise, cloud account compromise, insider threat, data exposure, lost device, third-party breach) are maintained by Security and tested by a **tabletop exercise at least twice a year**, including an executive-level exercise annually.

- On-call contacts, external forensics and legal counsel retainers, and cyber-insurance details are kept current and available offline.
- **Lost or stolen devices:** report within 1 hour (see 2.2, 4.2, 4.3). IT will lock or wipe the device and assess whether data was exposed.

7.5 On-Call and After-Hours Support

Purpose. To provide dependable support for critical services while treating on-call staff fairly. Pay, rest and scheduling for on-call employees are governed by HR 5.3.

- **Coverage.** SRE, Support and Security operate on-call rotations that give 24×7 coverage of Tier 0 services and security monitoring. Rotations, escalation paths and backups are published, with a primary, a secondary and a manager escalation.
- **Response.** On-call responders acknowledge SEV 1 pages within **15 minutes** and SEV 2 within **30 minutes**.
- **Tooling.** On-call staff use Company-issued devices and hardware security keys, and have approved secure remote access. They must not use personal accounts or unmanaged devices to fix production issues.
- **Handoffs and runbooks.** Rotations end with a written handoff. Runbooks are kept current and reviewed after each incident.
- **Sustainability.** Rotations are designed so no one is on the primary rota more than **one week in four** where team size allows, alert volume is monitored and reduced ("alert hygiene"), and rest rules in HR 5.3 apply after significant out-of-hours work.
- **Access.** On-call elevation follows the just-in-time process (3.4); break-glass use is logged and reviewed.

7.6 Capacity and Availability Management

- **Availability targets.** Each service has a target availability (for example, production platform **99.9%** monthly unless the customer contract says otherwise), measured and reported (see 1.6). Error budgets guide the balance between releasing new features and reliability work.

- **Monitoring.** Health, performance and capacity metrics are monitored with alerts on saturation and degradation. Alerts actionable by on-call have a runbook.
- **Capacity planning.** SRE reviews capacity, growth and cost **quarterly** for Tier 0 and Tier 1 services and before major launches, and load-tests significant changes.
- **Status page.** Customer-facing incidents and maintenance are posted on the public status page within **30 minutes** of a confirmed SEV 1 customer impact.
- **Service credits and SLAs.** Customer SLAs are approved by the head of Engineering, Legal and Finance before being signed (see 8.3).

Part 8 – Third Parties and Customers

8.1 Third-Party Risk Management

Purpose. To make sure vendors, service providers and partners that touch Simtora or customer data or systems are assessed, contracted and monitored. Commercial buying rules are in the Procurement Policy Manual (SIM-PRC-001, Part 4); this section covers the security and privacy layer.

Scope. SaaS, cloud and hosting providers, outsourced IT and development, managed security providers, data processors and subprocessors, staffing agencies with system access, consultants, and any partner with a connection to our systems.

Risk tiers and due diligence

Tier	Definition	Due diligence before contract	Ongoing
Critical	Hosts or processes Restricted data, or an outage would stop a Tier 0 service	Full security assessment: current SOC 2 Type II or ISO 27001 report, penetration test summary, architecture and data-flow review, subprocessor list, business-continuity evidence, financial stability check, Legal review of terms	Annual reassessment; review of attestation reports; quarterly service-level review; incident-notification contacts tested
High	Processes Confidential data, or has privileged network or application access	Security questionnaire and attestation review; Legal review	Annual review
Standard	Limited or no access to Company data	Basic review of security and privacy terms	Review at renewal

Contract requirements

Contracts with vendors in the Critical and High tiers must state, as a minimum:

- Roles and responsibilities, and defined **service levels**.
- Security obligations that are at least equal to this manual; encryption; access controls; secure development practices.
- **Confidentiality**, use only for the contracted purpose, and data return or deletion at end of contract (with certification within **30 days**).
- **Breach notification** to Simtora without undue delay and within **72 hours** of discovery (24 hours for Critical vendors where possible).

- Prior written approval for subcontracting, and flow-down of terms; disclosure of subprocessors and notice of changes.
- **Right to audit** or to receive independent audit reports; cooperation with Simtora's customers' audits where needed.
- Data protection terms (a data processing addendum) compliant with state privacy laws and, where relevant, GDPR/UK GDPR transfer mechanisms.
- Location of data and personnel access where required.
- Insurance including cyber liability at sensible limits (Legal and Finance set them by tier).
- Exit and transition support, and, for critical software, escrow or continuity terms (see 6.6).

Ongoing controls

- A **vendor register** lists each vendor, tier, data types, owner, contract dates, assessment results and open risks. The business owner is accountable for the relationship; Security is accountable for the risk assessment.
- Vendor access is limited, monitored and removed at contract end (see 8.2).
- IT monitors public breach news about key vendors, and vendors must tell Simtora about their own significant incidents.
- Sanctions and export screening of vendors is done through Legal and Procurement.
- Vendors that fail to meet requirements are given a remediation plan and deadline; if unresolved, the contract is exited or an exception is approved under 1.3.

8.2 Contractors and Third-Party Access

- **Business need and sponsor.** Access for contractors, consultants and vendor staff is granted only where there is a clear business need, a **named Simtora sponsor**, a signed agreement (including confidentiality and acceptable-use terms), and the approval of the relevant asset or data owner.
- **Least privilege and time limits.** Access is limited to what is needed, for a **fixed period that matches the contract** (default maximum 90 days, renewable), and expires automatically. The sponsor confirms the need at renewal.

- **Accounts and devices.** Third parties use named individual accounts (never shared), with MFA. They use Company-managed devices or approved virtual desktops for any access to Confidential or Restricted data; personal devices are not allowed.
- **Monitoring and reviews.** Third-party activity is logged, and their access is reviewed quarterly (see 3.5). Sponsors remove access immediately when work ends.
- **Screening and training.** Staffing agencies and service firms must confirm in writing that appropriate background checks, consistent with law, were completed for their personnel and that staff have completed security training. Contractors complete Simtora security awareness training within **30 days** (or before access to sensitive data).
- **Customer data.** Third-party access to customer data must comply with the relevant laws and customer contract.
- **Independent contractors** are not employees and are not covered by HR employment policies; this manual applies to them through their contract (see HR 1.2 for classification rules).

8.3 Customer Security Requirements and Assurance

Purpose. To meet the security commitments Simtora makes to its customers, and to give customers the assurance they need.

- **Security commitments.** Customer contracts, security addenda and data processing agreements are reviewed by Legal and Security before signature. Non-standard security commitments (for example, shorter breach-notice periods, specific certifications, customer-managed keys, data residency, background-check requirements or audit rights) need CISO approval, and are logged in the contract-obligations register so they can be met and tested.
- **Assurance program.** Simtora maintains an independent **SOC 2 Type II** report (Security, Availability and Confidentiality criteria at minimum) and aims for **ISO/IEC 27001** certification, renewed annually. Additional attestations, such as HIPAA-related or PCI DSS, are pursued only where the business requires them and after ITSC approval.
- **Security questionnaires and audits.** The Security Team, with Sales and Legal, answers customer questionnaires using a maintained answer library within **10 business days**, and supports customer audits under the contract. Answers are accurate;

misstatements about security are a compliance risk, and sales staff must not answer security questions themselves without Security review.

- **Trust center.** Security maintains a public or customer-only trust center with current certifications, policies summaries, subprocessors and status information.
- **Data protection.** Simtora acts as a processor or service provider for customer data unless stated otherwise; it processes customer data only on documented instructions, keeps a list of subprocessors, notifies customers of subprocessor changes as agreed, and supports customer data-subject requests.
- **Export controls and sanctions.** Legal classifies Simtora's products under the Export Administration Regulations, screens customers and users against sanctions and denied-party lists, and blocks access from embargoed jurisdictions.
- **Service commitments.** Uptime and support SLAs offered to customers are approved by the head of Engineering, Legal and Finance, and are achievable given the design (see 7.6).
- **Customer incidents.** Handled under 7.4. Only authorized staff communicate with customers about incidents.

Part 9 – Assurance and Enforcement

9.1 Security Awareness and Training

Purpose. To build a workforce that recognizes and resists threats.

Audience	Training	Timing
All employees, contractors and interns	Security awareness (phishing, passwords/MFA, data handling, AI use, reporting, physical security), privacy, and acceptable use	Within **30 days of hire** (consistent with HR onboarding), then **annually**
Everyone	Short micro-lessons and simulated phishing exercises	At least **monthly** simulations; extra coaching, not punishment, for those who click
Engineers	Secure coding and threat modeling	Within **60 days of hire**, then annually
Administrators and privileged users	Privileged-access and incident-handling training	Before receiving privileged access; annually
Managers	Their responsibilities for access, incidents and joiner/mover/leaver	At promotion or hire; annually
Executives and finance staff	Targeted training on business email compromise, wire-fraud and deepfake/voice-cloning scams	Annually
IT and Security staff	Role-specific training and certifications in the annual plan	Ongoing

- **Completion.** Managers ensure their teams finish on time. Overdue training is escalated to the manager after **10 business days** and department head after **20**; persistent non-completion may result in access being restricted until training is done, and can lead to corrective action under HR 2.3.
- **Records.** Completion is tracked centrally and reported to the ITSC (see 1.6). Records are retained for **3 years**.
- **Training needs to reflect the employee's role**, with accessible formats and reasonable accommodations (HR 4.1).

- **Phishing simulations** are used for education. Results are reported in aggregate, and individual performance is not used for performance ratings, though repeated high-risk behavior may be discussed with the manager for coaching.

9.2 Personnel Security

Purpose. To make sure the people with access are trustworthy and understand their duties.

- **Pre-employment screening.** Background and reference checks are carried out by HR before hire, in line with law (FCRA, state and local "ban-the-box" and fair-chance laws, and salary-history rules) and the role's access level. Checks for roles with privileged or Restricted-data access may be more extensive where the law allows and are disclosed in advance. Third-party staffing firms must attest to equivalent screening (see 8.2).
- **Terms of employment.** Employment terms, offer letters and the acknowledgement in Appendix A make security responsibilities part of every role. Employees sign a confidentiality and invention-assignment agreement (HR 1.8).
- **Role changes and leaving.** Access is adjusted when roles change and removed when people leave (see 3.3). Exit procedures include return of devices, reminders of continuing confidentiality obligations, and a sign-off from IT.
- **Insider risk.** Security runs a program to detect abnormal behavior (for example, mass downloads, use of unapproved storage) with privacy-respecting controls, defined triggers and the approval process in 4.8. Insider-risk concerns are handled with HR and Legal; employees are treated fairly and presumed to act in good faith.
- **Non-disclosure and protected activity.** Confidentiality obligations do not prohibit legally protected activity, such as reporting possible violations of law to a government agency, discussing pay and working conditions, or whistleblowing (see HR 3.3 and the Defend Trade Secrets Act notice in HR 1.8).
- **Discipline.** Non-compliance with this manual is handled under 9.5 and HR 2.3.

9.3 Risk Assessment, Testing and Audit

Purpose. To verify that controls exist, work, and keep pace with risk.

Risk assessment

- Security runs an **enterprise information-risk assessment at least annually** and whenever there is a major change (new product, acquisition, new cloud provider or new regulation). Results feed the risk register, which the ITSC reviews quarterly.
- Each risk has an owner, rating (likelihood and impact), treatment (mitigate, transfer, accept, avoid) and due date. Acceptance of risk is by the authority in the exception table (1.3).

Testing

Activity	Frequency	By
External penetration test of internet-facing products and infrastructure	**Annually** and after major changes	Independent third party
Internal network and cloud configuration penetration test	Annually	Independent third party
Application penetration tests for products	Annually, and before major releases	Independent third party
Social-engineering and phishing tests	At least twice a year	Security or third party
Red-team or purple-team exercise	Every 2 years (or as ITSC decides)	Third party
Disaster recovery and incident tabletop	See 7.3 and 7.4	Security, SRE
Backup restore tests	See 7.2	IT / SRE

- Findings are rated, tracked to closure, and reported to the ITSC. Remediation follows the timelines in 5.6. Any testing of production must be authorized in writing in advance, and tools for testing and audit are tightly controlled to prevent misuse.

Compliance monitoring and audit

- **Continuous control monitoring.** Automated compliance tooling tracks key controls (MFA coverage, encryption, patching, access reviews, backups) and reports drift.

- **Independent audits.** An independent auditor performs the annual SOC 2 Type II audit and any other certification audits. The Audit Committee is told of results and significant findings. Where Simtora or a customer requires it, IT general controls are tested as part of financial audit.
- **Internal review.** The Security Team, or an independent internal or external reviewer, checks compliance with this manual **at least annually**, sampling access reviews, change records, joiner/leaver, vendor assessments and exceptions. Pre- and post-implementation reviews are performed for major systems and changes to confirm a sound control environment.
- **Scope and timing** of audits are agreed in advance with the people audited, but unannounced spot checks (for example, of clear-desk or removable-media compliance) may also be carried out.
- **Findings** are recorded, assigned owners and due dates, and tracked to closure. Overdue high-risk findings are escalated to the CEO.

9.4 Vulnerability Disclosure

- **Reporting.** Security researchers, customers and members of the public may report suspected vulnerabilities in Simtora products or services to **security@simtora.example**, and the address and policy are published on the website (a `security.txt` file is maintained).
- **Good faith.** Simtora will not pursue legal action against researchers who follow the published policy, act in good faith, avoid privacy harm and service disruption, and give us reasonable time to fix issues. Legal approves the policy terms and safe-harbor language.
- **Handling.** Reports are acknowledged within **2 business days**, triaged by Product Security, and fixed within the timelines in 5.6. Reporters are kept informed and, where appropriate, credited.
- **Bug bounty.** A private or public bug-bounty program may be operated on approval of the ITSC.
- **Employee-found issues.** Employees who find a vulnerability in Company or third-party systems must report it to Security and must not exploit or test it beyond what is authorized.

9.5 Enforcement

- **Compliance is mandatory.** Everyone in scope must comply with this manual. Contractors and vendors are bound through their contracts.
- **Investigating violations.** Security, HR and Legal handle suspected violations fairly and confidentially, with the process in HR 2.3 for employees and following the monitoring rules in 4.8.
- **Consequences.** Depending on the seriousness, intent, harm and history, consequences include coaching and retraining, restricted or removed access, formal corrective action up to and including termination, termination of contractor or vendor agreements, recovery of costs where the law allows (never by wage deduction), and referral to law enforcement. Serious, deliberate breaches (for example, stealing data, sabotage, disabling controls to hide activity) may justify immediate termination after a fair review.
- **No retaliation.** Good-faith reporting of incidents, concerns or suspected violations is protected. Retaliation is a violation of policy and may itself be illegal.
- **Escalation.** Concerns about this manual or its application go to the Head of IT / CISO, then the CEO; ethics concerns go to **ethics@simtora.example**; concerns about the Head of IT / CISO or accounting and audit matters can go to **audit@simtora.example**.

Appendices

Appendix A – Policy Acknowledgement Form

Simtora Technologies, Inc. – IT Policy Acknowledgement (SIM-IT-001)

I confirm that I have received and read the Information Technology Policy Manual (Version _____). I understand that:

1. I must follow it whenever I use Simtora systems, data or devices, or personal devices that access Simtora data.

2. I am responsible for activity under my accounts and must not share credentials or MFA codes.
3. I must report security incidents, lost or stolen devices and suspected phishing immediately, and lost or stolen devices within 1 hour, without fear of retaliation for a good-faith report.
4. Company systems, accounts and devices, and the data on them, are Company property and may be monitored as described in Section 4.8 and HR Manual 1.9. **I have received notice of electronic monitoring**, including the notice required by state law where I work (for example, New York, Connecticut and Delaware). I understand that Simtora will not monitor personal accounts or personal devices except as they interact with Company systems, and will not use monitoring to interfere with legally protected activity.
5. I will use only approved software, tools and AI services, and will not enter Confidential or Restricted information into unapproved tools.
6. Nothing in this manual prohibits me from reporting possible violations of law to a government agency, discussing pay or working conditions with others, or engaging in other legally protected activity.
7. This manual is not a contract of employment and does not change at-will employment.

Name	Job title / department	Signature	Date

A copy is stored in the HR system. Acknowledgements are collected in the onboarding portal and after each material revision.

Appendix B – Joiner, Mover and Leaver Checklists

B1. Joiner

#	Task	Owner	Due
1	Hire recorded in HRIS; IT ticket created	HR	≥ 5 business days before start
2	Identity created; role-based groups assigned; email, chat, SSO ready	IT	Before day 1
3	Laptop selected, imaged, encrypted, enrolled in MDM, EDR installed; accessories prepared	IT	Before day 1
4	Welcome; device handed over and receipt signed; MFA (passkey and hardware key) registered	IT and new starter	Day 1
5	Password manager set up; VPN/zero-trust client tested	New starter with IT	Day 1
6	Acknowledgement (Appendix A) signed	New starter	Day 1
7	Additional access requested with business justification and owner approval	Manager	Week 1
8	Security awareness, privacy and acceptable-use training done	New starter	Within 30 days
9	Engineers: secure-coding training; repository access; production access (if role needs) after onboarding period	Manager, Engineering	Within 60 days
10	30-day check: training completion and access appropriate	Manager and IT	Day 30

B2. Mover

#	Task	Owner	Due
1	HR records the change and notifies IT	HR	Effective date
2			

B3. Leaver

#	Task	Owner	Due
1	HR notifies IT and Security of exit date (before the meeting, for involuntary exits)	HR	As soon as confirmed
2	Accounts disabled; sessions and tokens revoked; MFA methods removed	IT	End of last working day, or at time of notification for involuntary exits
3	Devices returned (or remotely locked and wiped if not returned); hardware keys and badges collected	Manager, IT, Facilities	Last day
4	Data and mailbox handover to manager; ownership of shared files, repos, calendars, and SaaS admin roles transferred	Manager and IT	Last day
5	Secrets, API keys, shared credentials and admin passwords known to the person rotated	IT / Security	2 business days (privileged); 10 business days (others)
6	Non-SSO SaaS accounts removed	Application owners	5 business days
7	Mailbox and personal drive retained then deleted (unless on legal hold)	IT	30 days
8	Reminder of confidentiality obligations; personal-device Company data removed	HR and IT	Last day
9	Checklist signed off by IT	IT	Within 5 business days

Appendix C – Security Incident Report Form

Field	Entry
Reporter (name, team, contact)	
Date and time of discovery	
Date and time of the event (if known)	
What happened? (facts only)	
Systems, accounts, devices or data involved	
Type of data possibly involved (Public / Internal / Confidential / Restricted; personal data?)	
Actions already taken	
Who else knows?	
Any evidence preserved (screenshots, emails, logs)? Do not forward suspicious files; attach only as instructed	
For IT/Security use: Incident ID, severity, incident commander, time acknowledged, legal notification decision, closure date	

Submit by the incident form, **security@simtora.example** or #security-incident. If in doubt, report it. Do not delay to complete the form.

Appendix D – Change Request Form

Field	Entry
Change ID / title	
Requester and owner	
Type (Standard / Normal / Emergency)	
Description and business reason	
Systems, environments and customers affected	
Risk and impact rating (Low / Medium / High) and rationale	
Security or privacy impact (data, access, new integrations)	
Test evidence (links to test results and scans)	
Implementation plan and schedule (date, window, duration)	
Rollback plan and success criteria	
Communication plan (internal, customers, status page)	
Peer reviewer / approver / CAB decision	
Post-implementation result and review notes	

Appendix E – Data Handling Matrix

Activity	Public	Internal	Confidential	Restricted
Storage	Any approved location	Approved Company systems	Approved Company systems with access control	Approved encrypted systems with named-access control; not on laptops except where technically required
Encryption at rest	Not required	Standard platform encryption	Required	Required, with managed keys
Encryption in transit	Recommended	Required (TLS 1.2+)	Required (TLS 1.2+)	Required (TLS 1.2+)
Sharing internally	Anyone	All staff	Need-to-know groups	Named individuals with owner approval
Sharing externally	Anyone	With business reason	Under NDA or contract, approved channel, named recipients, expiry	Only with data-owner and CISO approval; contract and legal basis required
Email	Allowed	Allowed	Avoid; use secure links	**Not allowed**; use secure transfer
Chat / messaging	Allowed	Allowed	Limited, private channels	**Not allowed** for content; use links to secured tools

AI tools	Allowed	Allowed	If tool is approved for Confidential	Only if specifically approved for Restricted
Unapproved / personal AI tools	Allowed	Not allowed	Not allowed	Never
Personal devices	Allowed	Enrolled devices via managed apps	Managed apps or virtual desktop only	**Not allowed** except via managed virtual environment
Removable media	Allowed	Blocked by default	Blocked; exception with encrypted media	Blocked; exception needs CISO approval
Printing	Allowed	Allowed	Avoid; secure release; shred	Avoid; CISO/owner approval; shred
Disposal	Normal	Recycle / delete	Shred; secure erase	Shred (cross-cut); cryptographic erase or destroy; certificate
Access review	–	Annual	Semi-annual	Quarterly

Appendix F – Exception Request Form

Field	Entry
Requester, department and sponsor	
Policy section for which an exception is requested	
Description of need and business reason	
Systems, data classification and users affected	

Appendix G – Approval Matrix

Decision or action	Requester / owner	Approver(s)
Adoption or major change to this manual	Head of IT / CISO	ITSC and CEO
Technical standards and procedures	Function owner	Head of IT / CISO
Policy exception – low risk	Requester	Head of IT / CISO
Policy exception – medium risk	Requester	Head of IT / CISO and department head
Policy exception – high risk	Requester	Head of IT / CISO and CEO
New software / SaaS / browser extension handling Company data	Requester	IT Security review; data owner
New tool handling Restricted data	Requester	CISO and General Counsel
Approved AI tool (adding to list)	Requester	IT Security and Legal
AI agent with write access to production	System owner	CISO and named owner
Standard access	Employee / manager	Manager and system/data owner
Restricted-data or production access	Employee / manager	System/data owner and Security
Privileged just-in-time elevation	Engineer	Approver per service (peer or manager), logged
Access to another employee's mailbox or files	HR, Legal or Security	General Counsel and Chief People Officer (CISO with Legal in security incidents)

Appendix H – Key Standards at a Glance

Topic	Standard	Section
Lost or stolen device reporting	Within **1 hour** of discovery	7.4, 4.2
Security training	Within **30 days** of hire; annually	9.1
MFA	Required for all; phishing-resistant for privileged access	3.2
Password length	14 characters (20 for privileged); no periodic rotation; blocklist	3.2
Screen lock	10 minutes (laptop); 2 minutes (phone)	4.2
Laptop refresh	4 years	2.2
New joiner access	Ready on day 1	3.3
Leaver access	Disabled by end of last day; immediately for involuntary	3.3
Mover access removal	Within 2 business days	3.3
Access reviews	Quarterly (privileged, production, Restricted, financial); semi-annual (others)	3.5
Critical vulnerability fix	72 hours (internet-facing/Tier 0); 7 days (other)	5.6
Log retention	12 months (90 days searchable)	5.5
Backup restore tests	Tier 0 quarterly; Tier 1 semi-annually; Tier 2 annually	7.2
Tier 0 recovery targets	RPO 15 min / RTO 4 hours	7.2
Incident severity SEV 1	Response within 15 minutes; execs within 1 hour	7.4
Customer breach notice	Per contract, typically within 72 hours	7.4
Post-incident review	Within 10 business days	7.4
Penetration tests	Annually	9.3

Appendix I – Glossary

Term	Meaning
AI tool / agent	Software that uses machine learning or generative models to produce output or act on a user's behalf
BYOD	Bring your own device: personal phones or tablets used for work under MDM
CAB	Change Advisory Board that reviews high-risk changes
CISO	Chief Information Security Officer; here the Head of IT / CISO
Data owner	Business leader accountable for a data set, who classifies it and approves access
DLP	Data loss prevention controls that prevent sensitive data from leaving approved channels
DR / BCP	Disaster recovery / business continuity planning
EDR	Endpoint detection and response software
IdP / SSO	Identity provider / single sign-on
ITSC	IT & Security Steering Committee
Just-in-time (JIT) access	Temporary, approved elevation of access that expires automatically
KEV	CISA's Known Exploited Vulnerabilities catalog
Least privilege	Giving only the minimum access needed
MDM / UEM	Mobile device management / unified endpoint management
MFA	Multi-factor authentication
Phishing-resistant MFA	Authentication (such as FIDO2 keys or passkeys) that can't be tricked by fake login pages
Restricted data	Highest classification, including customer and personal data, credentials and keys
RPO / RTO	Recovery point objective (data loss tolerance) / recovery time objective (downtime tolerance)

Appendix J – Revision History

Version	Date	Author	Summary of changes	Approved by
1.0	September 30, 2026	Head of IT / CISO	Initial release	CEO
1.1	October 5, 2026	Head of IT / CISO	Added "Locations outside the United States"; amended data location (2.5) and working outside the country of employment (4.6); cross-references to SIM-GLB-001 Part 1	CEO

Annual review record: record the date and reviewer of each annual review here, even where no changes were made.